PeriGen Inc.

HIPAA
PRIVACY AND SECURITY
POLICY AND PROCEDURES MANUAL

2019

Proprietary and Confidential

HIPAA PRIVACY AND SECURITY
OVERVIEW

PeriGen Inc. ("PeriGen") Privacy and Security Policy and Procedure Manual is written to affirm PeriGen's commitment to comply with the Health Insurance Portability and Accountability Act of 1996 (HIPAA), the Health Information Technology for Economic and Clinical Health Act (HITECH Act), and the implementing regulations that went into effect in September, 2013. As a Business Associate, PeriGen agrees to comply with certain provisions of the HIPAA Privacy and Security Regulations. PeriGen is directly liable to the Department of Health and Human Services for non-compliance with the HIPAA Privacy and Security Regulations and for all Breaches of unsecured PHI. As a result, PeriGen's and its Workforce Members' compliance with the HIPAA and HITECH Privacy and Security Policies and Procedures included in this manual is crucial.

HIPAA SECURITY REGULATIONS

Under the HIPAA Security Regulations, Covered Entities, and now Business Associates, are required to implement administrative, physical, and technical safeguards that ensure the confidentiality, integrity, and availability of ePHI. These safeguards are designed to:

1. Ensure the confidentiality, integrity, and availability of all ePHI it creates, receives, maintains, or transmits;

2. Protect against any reasonably anticipated threats or hazards to the security or integrity of such information;

3. Protect against any reasonably anticipated uses or disclosures of such information that are not permitted by the HIPAA Privacy Regulations; and

4. Ensure compliance with the HIPAA Security Regulations by its workforce.

The Security Policies and Procedures in this manual address PeriGen's obligations under the HIPAA Privacy and Security Regulations. In designing these policies and procedures, PeriGen and its legal counsel have considered:

1. PeriGen's size, complexity, and capabilities;
2. The nature of PeriGen's interaction with its clients' ePHI;
3. PeriGen's technical infrastructure, hardware, and software security capabilities;
4. The costs of security measures; and
5. The probability and criticality of potential risks to ePHI.

As part of its compliance with the HIPAA Security Regulations, PeriGen has installed a Privacy & Security Officer who will oversee PeriGen's efforts to create and maintain appropriate and reasonable policies, procedures, and controls to protect the security of ePHI that PeriGen creates, receives, maintains, or transmits and ePHI Systems that PeriGen accesses, owns, or operates. PeriGen's Privacy & Security Officer will be assisted regularly by the entity's Director of Quality and Regulatory. The Director of Quality and Regulatory affairs job description specifically includes assisting the Privacy & Security Officer with ensuring PeriGen's workforce members comply with the Security Rule.

HIPAA PRIVACY REGULATIONS

The HIPAA Privacy Regulations provide rules regarding the use and disclosure of PHI, and other rules regarding an individual's right to access PHI about himself contained in certain records. As a Business Associate, PeriGen agrees to follow all requirements of the HIPAA Privacy and Security Regulations as mandated by HIPAA and the HITECH Act. PeriGen's Privacy and Security Officer, with the assistance of Director of Quality and Regulatory will oversee its efforts to comply with the HIPAA Privacy and Security Regulations and its efforts to protect the privacy and security of all ePHI that PeriGen creates, transmits, maintains, and/or accesses. PeriGen will consistently monitor and periodically audit its practices to ensure compliance with the Privacy and Security Policies and Procedures.

EDUCATION AND COMPLIANCE WITH THE HIPAA PRIVACY AND SECURITY POLICIES AND PROCEDURES

PeriGen will provide training for all Workforce Members regarding the Privacy and Security Policies and Procedures included in this manual. All Workforce Members are required to certify in writing, by signing the Workforce Member Compliance Statement included in this manual, that they have received, read, received training on, understand and agree to follow those policies in this manual that apply to Workforce Members and all applicable provisions of HIPAA and the HITECH Act. Also, as part of their compliance with these Policies and Procedures, Workforce Members must certify that they will protect the confidentiality of PHI, including ePHI, and that they will report any unauthorized disclosures of PHI or ePHI or other Security Incidents to the Security Officer, as specified in this manual. The Privacy and Security Officers will maintain a record on each Workforce Member that includes his or her signed Workforce Member Compliance Statement. Any violations of these Security Policies and Procedures on the part of any Workforce Member may lead to the imposition of sanctions, up to and including termination.

#	Policy/Procedure	Revision	Effective Date
1	Workforce Member Confidentiality and Compliance Statement	**1.0**	**10/01/2018**
2	Privacy and Security Awareness and Training	**1.0**	**10/01/2018**
3	Workforce Member Discipline	**1.0**	**10/01/2018**
4	Disciplinary Action Policy for Self-Reported Minor Violations	**1.0**	**10/01/2018**
5	Breach Notification	**1.0**	**10/01/2018**
6	Business Associate Agreements	**1.0**	**10/01/2018**
7	Notice of Privacy Practices	**1.0**	**N/A**
8	Uses and Disclosures of PHI	**1.0**	**N/A**
9	Minimum Necessary Standard	**1.0**	**10/01/2018**
10	De-Identification of PHI	**1.0**	**10/01/2018**
11	Access of Individuals to PHI	**1.0**	**N/A**
12	Amendment of PHI	**1.0**	**N/A**
13	Accounting of Disclosures of PHI	**1.0**	**N/A**
14	Facsimiles	**1.0**	**10/01/2018**
15	Assigned Privacy Responsibility	**1.0**	**10/01/2018**
16	Security Analysis and Risk Management	**1.0**	**10/01/2018**
17	Information System Activity Review; Audit Controls	**1.0**	**10/01/2018**
18	E-mail Audit Policy	**1.0**	**10/01/2018**
19	Assigned Security Responsibility	**1.0**	**10/01/2018**
20	Workforce Member Security	**1.0**	**10/01/2018**
21	Information Access Management	**1.0**	**10/01/2018**
22	Termination Procedures	**1.0**	**10/01/2018**
23	Security Reminders	**1.0**	**10/01/2018**
24	Malicious Software	**1.0**	**10/01/2018**

25	Log-In Monitoring	**1.0**	**10/01/2018**
26	Password Management	**1.0**	**10/01/2018**
27	Security Incident Procedures	**1.0**	**10/01/2018**
28	Contingency Plan	**1.0**	**10/01/2018**
29	Data Backup Plan and Disaster Recovery Plan	**1.0**	**10/01/2018**
30	Emergency Mode Operation Plan	**1.0**	**10/01/2018**
31	Applications and Data Criticality Analysis	**1.0**	**10/01/2018**
32	Evaluation of Security Policies and Procedures	**1.0**	**10/01/2018**
33	Facility Access and Security	**1.0**	**10/01/2018**
34	Workstation Use and Security	**1.0**	**10/01/2018**
35	Device and Media Controls	**1.0**	**10/01/2018**
36	Technical Access Controls	**1.0**	**10/01/2018**
37	Mobile Device Management (MDM)	**1.0**	**10/01/2018**
38	Integrity	**1.0**	**10/01/2018**
39	Person or Entity Authentication	**1.0**	**10/01/2018**
40	Transmission Security	**1.0**	**10/01/2018**
41	Availability	**1.0**	**10/01/2018**
42	Updates	**1.0**	**10/01/2018**

POLICY AND PROCEDURE DOCUMENTATION AND REVISION

PeriGen will continue to review and, as necessary, revise and update these Policies and Procedures to comply with the applicable HIPAA Privacy and Security Regulations or any changes in North Carolina law; to address any operational changes at PeriGen; to incorporate new technologies that protect the confidentiality, integrity and availability of ePHI; and to address any threats to the privacy or security of PHI that PeriGen may encounter in the future. PeriGen will make these Privacy and Security Policies and Procedures easily accessible to all Workforce Members. Also, PeriGen will document any revisions made to these Policies and Procedures and will notify its Workforce Members of relevant changes. Documentation recording any changes or modifications to these Policies and Procedures will be maintained for at least five years.

POLICY TABLE OF CONTENTS

DEFINED TERMS

Addressable: The concept of "addressable implementation specifications" was developed to provide covered entities additional flexibility with respect to compliance with the security standards. In meeting standards that contain addressable implementation specifications, PeriGen will do one of the following for each addressable specification: (a) implement the addressable implementation specifications; (b) implement one or more alternative security measures to accomplish the same purpose; (c) not implement either an addressable implementation specification or an alternative. PeriGen's choice must be documented. PeriGen must decide whether a given addressable implementation specification is a reasonable and appropriate security measure to apply within its particular security framework. For example, PeriGen must implement an addressable implementation specification if it is reasonable and appropriate to do so and must implement an equivalent alternative if the addressable implementation specification is unreasonable and inappropriate, and there is a reasonable and appropriate alternative. This decision will depend on a variety of factors, such as, among others, PeriGen's risk analysis, risk mitigation strategy, what security measures are already in place, and the cost of implementation. The decisions that PeriGen makes regarding addressable specifications must be documented in writing. The written documentation should include the factors considered as well as the results of the risk assessment on which the decision was based.

Administrative Safeguards: Administrative Safeguards are actions, policies and procedures to manage the selection, development, implementation, and maintenance of security measures to protect ePHI and to manage the conduct of PeriGen's Workforce Members in relation to the protection of ePHI.

Breach: Breach means the unauthorized acquisition, access, use, or disclosure of PHI, which compromises the security or privacy of such information, except where (1) the unintentional acquisition, access or use was by a Workforce Member acting under authority of the Covered Entity or Business Associate, if done in good faith and within the scope of authority and further use or disclosure contrary to the Privacy Regulations does not occur; (2) the inadvertent disclosure by a person authorized to access PHI at a Covered Entity or Business Associate was to another person authorized to access PHI at the same organization and the information is not further used or disclosed contrary to the Privacy Regulations; or (3) an unauthorized person to whom such information is disclosed would not reasonably have been able to retain such information.

Business Associate: A Business Associate is a person or entity who, on behalf of a Covered Entity, (1) performs, or assists in the performance of a function or activity involving the use or disclosure of individually identifiable health information, including, but not limited to, claims processing or administration; data analysis, processing or administration; utilization review; quality assurance; billing; benefit management; or practice management or (2) who provides, other than as a Workforce Member, legal, actuarial, accounting, consulting, data aggregation, management, administrative, accreditation, or financial services to or for a Covered Entity.

Contingency Event: A Contingency Event is an unplanned for event, such as an emergency or disaster, which may require the activation of PeriGen's Contingency Plan, Data Back-Up Plan, Disaster Recovery Plan, or Emergency Operations Plan.

Covered Entity: A Covered Entity is (i) a health plan, (ii) a health care clearinghouse, or (iii) a health care provider who transmits any health information in any form, including in electronic form.

Electronic Protected Health Information or ePHI: Electronic PHI means PHI, which is either transmitted by electronic media or maintained in electronic media.

Electronic Protected Health Information System or ePHI System: ePHI System means any electronic system owned, operated or accessed by PeriGen or its Workforce Members, which processes, stores or transmits ePHI. ePHI Systems include, but are not limited to, servers, database applications, networks, email systems and Web applications used to access ePHI.

IT Officer: IT Officer means a PeriGen employee who has been appointed by the Management Committee to assist the Security Officer. The IT Officer should possess an advanced understanding of information technology systems. The IT Officer position is an optional position that may or may not be filled, at the pleasure of the Management Committee. The IT Officer reports directly (or dotted line) to the Chief Product Officer.

Organized Health Care Arrangement, or "OHCA": an OHCA is:

1. A clinically integrated care setting in which individuals typically receive health care from more than one provider;

2. An organized system of health care in which more than one covered entity participates and in which the participating covered entities:

    A. Hold themselves out to the public as participating in a joint arrangement; and

    B. Participate in joint activities that include at least one of the following:

        i. Utilization review, in which health care decisions by participating covered entities are reviewed by other participating covered entities or by a third party on their behalf;

        ii. Quality assessment and improvement activities, in which treatment provided by participating covered entities is assessed by other participating covered entities or by a third party on their behalf; or

        iii. Payment activities, if the financial risk for delivering health care is shared, in part or in whole, by participating covered entities through the joint arrangement and if PHI created or received by a covered entity is reviewed by other participating covered entities or by a third party on their behalf for the purpose of administering the sharing of financial risk.

3. Certain categories of group health plans as further described in Section 160.103.

Physical Safeguards: Physical Safeguards are physical measures, policies, and procedures to protect PeriGen's ePHI Systems and related buildings and equipment, from natural and environmental hazards, and unauthorized intrusion.

Protected Health Information or PHI: PHI means health information that is individually identifiable.

Relatively Minor Violation: A violation of the policies and procedures set forth herein, that the Security Officer determines has a low probability of resulting in a Breach or violation of law.

Required: Required refers to implementation specifications contained within certain HIPAA regulations with which PeriGen must comply.

Security Incident: Security Incident means the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations in ePHI Systems.

Significant Violation: A violation of the policies and procedures set forth herein, that the Security Officer determines has a moderate or high probability of resulting in a Breach or violation of law.

Subcontractor: A subcontractor is a person or entity to which a business associate delegates a function, activity or service in a capacity other than as a member of the workforce of such business associate.

Technical Safeguards: Technical Safeguards means the technology and the policy and procedures that PeriGen has to protect ePHI and control access to it.

Vendor: Vendor means a vendor, consultant, contractor or other non-PeriGen third party who may have access to ePHI or an ePHI System for any reason or purpose (other than those who may have incidental access) or who may have access to any PeriGen facilities housing the information technology assets that support ePHI or ePHI Systems or related infrastructure.

Workforce Member: All persons who are under the direct control of PeriGen, including, but not limited to, employees, interns, certain independent contractors whose primary work assignment is with PeriGen, and temporary personnel.

Workstation: Workstation means an electronic computing device, for example, a laptop or desktop computer, or any other device that performs similar functions, and electronic media stored in its immediate environment.

HIPAA Privacy and Security Policies and Procedures

	General HIPAA Policies	Procedure No. 1
Title: Workforce Member Confidentiality and Compliance Statement	**Revision 1.0**	**Effective Date**

Purpose Statement: All Workforce Members are required to certify in writing, by signing the Workforce Member HIPAA Compliance and Confidentiality Statement provided below, that they have received, read, received training on, understand and agree to follow the policies in the manual provided to them and all applicable provisions of HIPAA and the HITECH Act. Also, as part of their compliance with these Policies and Procedures, Workforce Members must certify that they will protect the confidentiality of PHI, including ePHI, and that they will report any unauthorized disclosures of PHI or ePHI and other Security Incidents to the Security Officer or Privacy Officer, as specified in this manual.

Policy/Procedure:

1. All Workforce Members will sign the Workforce Member HIPAA Compliance and Confidentiality Statement provided below prior to being given access to PHI, ePHI or ePHI Systems and annually thereafter.
2. The Privacy & Security Officer, Human Resources Manager and/or The Director of Quality and Regulatory will ensure a maintained record on each Workforce Member that includes the original or electronically, signed Workforce Member HIPAA Compliance and Confidentiality Statement. Each Workforce Member HIPAA Compliance and Confidentiality Statement signed by a Workforce Member must be maintained for at least six years from the date of the Workforce Member's signature.

3. The Human Resources Manager or Director of Quality and Regulatory will return a copy of the signed Workforce Member HIPAA Compliance and Confidentiality Statements to the Workforce Member.
4. Any Workforce Member who refuses to sign the Workforce Member HIPAA Compliance and Confidentiality Statement will be denied access to PHI, ePHI, or ePHI Systems.
5. Any Workforce Member who refuses to sign the Workforce Member HIPAA Compliance and Confidentiality Statement may be terminated because that Workforce Member will not be able to perform the essential function of his or her job.

EXAMPLE - WORKFORCE MEMBER HIPAA COMPLIANCE AND CONFIDENTIALITY STATEMENT

I, ___, acknowledge that I have received, read, received training on, understand and agree to follow the PeriGen HIPAA Privacy and Security Policies and Procedures that have been provided to me. Also, I acknowledge that during the course of performing my assigned duties at PeriGen, I may have access to, use, or disclose Protected Health Information (PHI) or electronic PHI (ePHI). I agree to handle such information in a confidential manner at all times during and after my employment and commit to the following obligations:

1. I will use and disclose PHI, including ePHI, only in connection with and for the purpose of performing my assigned job functions.

2. I will request, obtain, or communicate PHI, including ePHI, only as necessary to perform my assigned job functions and will refrain from requesting, obtaining or communicating more PHI, including ePHI, than is necessary to accomplish such functions.

3. I will use reasonable diligence† to properly secure PHI, including ePHI, on my Workstation and will take steps to ensure that others cannot view or access such information. These steps include but are not limited to utilizing a locked bag when transporting PHI.

4. I will use and disclose PHI, including ePHI, solely in accordance with the applicable federal and state laws and regulations and the PeriGen HIPAA Privacy and Security Policies and Procedures. I also agree, in a timely manner, to familiarize myself with any periodic updates or changes to these policies that are communicated to me.

5. I will immediately report any unauthorized use or disclosure of PHI, including ePHI, that I become aware of to the appropriate PeriGen Official.

6. I understand and agree that my failure to fulfill any of the obligations set forth in this Statement and any failure to comply with PeriGen's HIPAA Privacy and Security Policies and Procedures will result in my being subject to appropriate disciplinary action.

_____ _____

Workforce Member's Signature Security Officer's Signature

_____ _____

Workforce Member's Printed Name Date

Workforce Member's Job Title/Department

Director of Quality and Regulatory Signature

Date

Date

†Reasonable Diligence is defined by HIPAA (45 CFR 160.401) to mean "the business care and prudence expected from a person seeking to satisfy legal requirements under similar circumstances."

Responsibility: Privacy Officer
Regulatory Category: Privacy Regulations; Security Regulations **Revision History:**

Revision Level	Revision Description	Effective Date
1	Initial Policy	October 1, 2018

	General HIPAA Policies	Procedure No. 2
Title: Privacy and Security Awareness and Training	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: Implement a security awareness and training program for members of its workforce (including management). 45 CFR § 164.308(a)(5)(i).

HIPAA Privacy Rule Language: A covered entity must train all members of its workforce on the policies and procedures with respect to protected health information required by the HIPAA Privacy Rule, as necessary and appropriate for Workforce Members to carry out their functions. 45 CFR 164.530(b)

Provide training to employees regarding state and federal law concerning protected health information as necessary and appropriate for the employees to carry out the employees' duties. If the duties of an employee are affected by a material change in state or federal law concerning protected health information, the employee shall receive training within a reasonable period, but within one year of the effective date of the change in the law.
Section 181.101 Health and Safety Code

Purpose Statement: PeriGen has the responsibility under the HIPAA Privacy and Security Regulations for providing and documenting privacy and security awareness and training for PeriGen Workforce Members in order that those persons can properly carry out their functions while appropriately safeguarding PHI and ePHI. This policy reflects PeriGen's commitment to comply with such Regulations.

Policy/Procedure:

1. PeriGen's Human Resource manager will provide training and supporting reference materials to its Workforce Members, as appropriate, to carry out their functions with respect to the privacy and security of PHI and ePHI.
2. PeriGen's Human Resource manager will provide training for new Workforce Members' orientation. The Workforce Members' orientation will occur before any access to PHI is granted and in any case no later than 90 days after the new Workforce Member's onboarding date. With respect to current Workforce Members, PeriGen will provide training to any employees as of the date of this policy who have not yet undergone Privacy and Security Awareness Training, if any. To the extent that a material change in state or federal law and/or the Policies and Procedures in this Manual affects a Workforce Member's function at PeriGen, PeriGen will provide additional training within a reasonable period of time. With

respect to a material change in state or federal law, the training must take place no later than one year after the material change becomes effective.

3. As part of its risk analysis, pursuant to its Security Risk Management Policy, PeriGen will determine how often any additional training will be required for its Workforce Members and Users and the method of such training.
2. PeriGen will maintain sufficient records that document and confirm a Workforce Member's completion of Privacy and Security Awareness Training, such as a document signed by each Workforce.
3. Security awareness training should include information to make Workforce Members aware of and familiar with PeriGen's HIPAA Security Policies and Procedures.
4. PeriGen will provide security information reminders and updates to its Workforce Members, in accordance with the PeriGen Security Reminders Policy.
5. PeriGen will make these Policies and Procedures available for reference and review by its Workforce Members who have access to PHI and/or ePHI.

Responsibility: Human Resource Manager

Definitions: Workforce Member; ePHI; ePHI System

Regulatory Reference:

- ♦ 45 C.F.R. §164.308(a)(5)(i), Security Awareness and Training [Standard; Required]
- ♦ 45 C.F.R. 164.530(b), Training [Standard; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1	Initial Policy	October 1, 2018

	General HIPAA Policies	Procedure No. 3
Title: Workforce Member Discipline	**Revision 1.0**	**Effective Date**

Purpose Statement: PeriGen will apply sanctions against Workforce Members, as appropriate, for violations of these HIPAA Privacy and Security Policies and Procedures. PeriGen has chosen a Privacy and Security Officer who, has the requisite authority to ensure the entity properly sanctions Workforce Members as appropriate.

Policy/Procedure:

MINOR OCCURRENCES

If the Privacy Officer determines that a Workforce Member's acts or omissions resulted in a Relatively Minor Violation of these HIPAA Privacy and Security Policies and Procedures and no significant violation of any law or regulation, the Privacy Officer will determine whether or not further education, clarification, or other corrective actions are needed. All minor violations will be tracked and reviewed; disciplinary action self-reported violations are outlined in PeriGen's "Disciplinary Action for Self-Reported Violations" Policy (see attached).

SIGNIFICANT VIOLATIONS

If the Privacy Officer determines that a Workforce Member's acts or omissions resulted in a Significant Violation of these HIPAA Privacy and Security Policies and Procedures or a violation of any law or regulation, the Privacy Officer will report the findings to the Management Committee and will recommend appropriate disciplinary action. The Management Committee will then determine the scope of any disciplinary steps to be taken.

DISCIPLINARY ACTION

1. Disciplinary action should be imposed commensurate with the seriousness of the security or privacy violation. The forms of discipline are listed in the "**PeriGen Privacy & Security Disciplinary Action Forms"** (attached) and will be followed based on the severity of the violation and according to the type of Workforce Member

2. The Management Committee may consult with legal counsel at its discretion to determine what disciplinary action is appropriate.

3. For self-reported minor violations: See "**Disciplinary Action Policy for Self-Reported Minor Violations**" Policy #4.

Responsibility: Privacy & Security Officer; Management Committee
Definitions: Workforce Member
Regulatory Reference:

- ♦ 45 C.F.R. §164.308(a)(1)(ii)(C), Sanction Policy [Implementation Specification; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1	Initial Policy	October 1, 2018

EXAMPLE -
PeriGen Privacy & Security Disciplinary Action Plan:

Staff:

Based on the severity of the incident, the order of warnings and course of action are at the discretion of the Privacy and Security Officer, the Privacy & Security Committee and/or the executive leadership of PeriGen. If warranted, an incident can be immediately escalated to the highest tier of action if the event is a repeat occurrence or severe in nature.

1. Tier 1
    a. Oral warning by executive team and/or;
    b. Written warning in file with associated signatures (if applicable) and/or;
    c. Required additional HIPAA training that is specific to the incident

2. Tier 2
    a. Oral warning by PeriGen's Privacy and Security Officer and/or executive team and/or;
    b. Written warning in file with associated signatures (if applicable) and/or;
    c. Required additional HIPAA training that is specific to the incident and/or;
    d. Required to repeat all parts of the PeriGen Privacy and Security training module.

3. Tier 3
    a. Oral warning by PeriGen's Privacy and Security Officer and/or executive team;
    b. Written warning in file with associated signatures (if applicable);
    c. Required additional HIPAA training that is specific to the incident;
    d. Required to repeat all parts of the PeriGen Privacy and Security-training module.
    e. Meeting with the executive team and PeriGen's Privacy & Security Officer to discuss further action. Disciplinary actions may include the following:
        i. Suspension without pay
        ii. Reassignment
        iii. Termination

NOTE: *If a workforce member does not complete the assigned disciplinary action as outlined in Tier 1 or 2 by the due date, we reserve the right to escalate the matter to the highest tier.*

	Revision	Procedure No. 4
Title: Disciplinary Action Policy for Self-Reported Minor Violations	**1.0**	**Effective Date**

Purpose: To structure disciplinary action around workforce members who have self-reported multiple minor violations throughout one calendar year. This policy **ONLY pertains to self-reported** violations. Any violation that is found during an audit that was not reported (either by the violator or a known party) will be escalated appropriately. Furthermore, any violation that was done **with intent** will not fall under the provisions of this policy, regardless if it is self-reported.

Policy: Within one calendar year a workforce member is allowed to make 3 "minor" violations that will be categorized a "Tier 1 violation*" but ***may not*** be subject to any formal write up or additional training. On the 4th violation within the calendar year, the discipline plan is **automatically** escalated to a "Tier 2 violation". Of note, if a violation is deemed to be significantly large in scale or considered a breach, it will be handled as such and will not be applicable to this policy.

**Please refer to the "Disciplinary Action Plan" for reference on Tier 1, 2,3 & 4 disciplinary action for workforce members.*

Provisions of policy:

1. Each workforce member has a maximum of 3 accidental/self-reported violations per calendar year before automatically being escalated to Tier 2 level of disciplinary action *(The Privacy & Security Officer will determine if an incident is minor enough to be included under this guideline- if not the incident will follow normal Tier protocol based on the level of severity. Please refer to the "Disciplinary Action Plan" for reference on Tier 1, 2, 3 & 4 disciplinary action for workforce members.)*

2. All self-reported violations are kept on an excel sheet and documented through a HIPAA decision form, signed by the Director of Quality and Regulatory as well as the Privacy & Security Officer. This log has been active since October 1, 2018 and is updated as incidents occur.

3. Any self-reported violation that has occurred up until the adoption of this policy will be given to the Chief Operating Officer in a summary report for review

Effective Date: This policy has an effective date of October 01, 2018

1. The disciplinary portion of this rule will **not** be applied retroactively from its **effective date** under the following provisions:

a. Any self-reported violation that has occurred up until the adoption date of this policy will be given to the Chief Operating Officer in a summary report for review.

b. All self-reported violations from the policy adoption date (10/03/18) until its effective date (7/1/18) will still be reviewed on a case-by-case basis by the Director of Quality and Regulatory and the Privacy & Security Officer. Once the violation is reviewed and the involved party is contacted, the findings will be logged. The Director of Quality & Regulatory will present a summary of violations to the Chief Product Officer for review on a monthly basis.

c. If a workforce member has a ***recurring or historical*** trend of "self-reported/accidental" violations, it will be discussed with the Chief Product Officer and the Privacy & Security Officer and an action plan will be decided.

d. The log of self-reported incidents will be maintained, monitored and shared with the Chief Product Officer from the effective date of this policy (7/1/18) and beyond.

Reviewed By:

Approved By: Privacy and Security Officer

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

HIPAA Breach Notification Rule Language:
"If a breach of unsecured protected health information occurs at or by a business associate, the business associate must notify the covered entity following the discovery of the breach. A business associate must provide notice to the covered entity without unreasonable delay and no later than 60 days from the discovery of the breach. To the extent possible, the business associate should provide the covered entity with the identification of each individual affected by the breach as well as any other available information required to be provided by the covered entity in its notification to affected individuals. "

Purpose Statement: PeriGen must report Breaches to the Covered Entity, whose unsecured PHI has been or is reasonably believed by the Covered Entity to have been, accessed, acquired, used, or disclosed. A Covered Entity has an obligation to notify the Secretary of Department of Health and Human Services (HHS) and, depending on the number of individuals affected by the Breach, the media. A Covered Entity shall provide notification required without unreasonable delay and in no case later than 60 calendar days of discovery of the Breach. To the extent that PeriGen maintains any "computerized data," PeriGen will also comply with the notification requirements applicable to it under the applicable state law.

Policy/Procedure:

BREACHES

1. This Breach Notification Policy applies only to PHI that is "unsecured." Under HIPAA, "Unsecured" PHI is that PHI which is not secured through a technology or methodology that HHS has stated renders the PHI unusable, unreadable, or indecipherable to unauthorized individuals. For both HIPAA and the applicable state law, data would not be considered "secured" if it was encrypted data but the decryption key was breached or otherwise available to an unauthorized recipient
2. PHI is secured through encryption (for ePHI) or destruction (for PHI in all other formats).
3. PeriGen will take all measures necessary to secure PHI in accordance with the Device and Media Controls, Technical Access Controls and Transmission Security Policies included in this manual.
4. In addition, the following occurrences are not Breaches:
    a. Any unintentional acquisition, access, or use of PHI by a Workforce Member, or individual acting under the authority of PeriGen if:
        i. Such acquisition, access, or use was made in good faith and within the course and scope of the employment or other professional relationship of such Workforce Member or other individual, respectively, with PeriGen; and
        ii. Such information is not further acquired, accessed, used, or disclosed by any person.

b. Any inadvertent disclosure from an individual who is otherwise authorized to access PHI at a facility operated by PeriGen to another similarly situated individual at the same facility and any such information received as a result of such disclosure is not further acquired, accessed, used, or disclosed without authorization by any person.

DISCOVERY OF BREACH

1. Any Workforce Member who discovers a suspected Breach must immediately notify the Privacy & Security Officer. The Workforce Member may notify the Privacy & Security Officer of the occurrence of a suspected or potential Breach in any format, including in writing, electronically, or orally. The Privacy & Security Officer will document the report of a potential Breach along with the date and time that he or she was notified of such event.
2. If the Breach is a Security Incident, the Privacy & Security Officer will investigate the Security Incident in accordance with the Security Incident Procedures Policy.
3. If the Breach is not a Security Incident, the Privacy & Security Officer will proceed as follows:
   a. The Privacy & Security Officer will notify PeriGen Leadership.
   b. The Privacy & Security Officer will notify legal counsel of the suspected Breach.
   c. If the potential Breach involves PHI that PeriGen received as a Business Associate, legal counsel will determine how the potential Breach should be reported. Legal counsel will also determine whether any additional notifications are required pursuant to applicable breach notification laws.
   d. In consultation with legal counsel and the Management Committee, the Privacy & Security Officer will conduct an initial review of the suspected Breach to determine whether a Breach occurred and, if so, the scope, magnitude and severity of the Breach; mechanisms for mitigating the harmful effects of the Breach; and, ways to remediate the vulnerability that lead to the Breach.
   e. PeriGen will use all appropriate measures to conduct and complete its review of the suspected Breach within a reasonable time after the discovery of the Breach. However, the review period must be complete within 5 days after the Breach's discovery.
   f. If the review shows that the Breach affected PHI owned and managed by another entity (hospital, health system, etc.), PeriGen will notify the entity immediately after the review period.
   g. If the review shows that no Breach has occurred, the Privacy & Security Officer will document this in a report along with all of the information that supports such conclusion and no further investigations or procedures are required.
   h. If the review shows that a Breach has occurred and affects PHI owned and managed by PeriGen, PeriGen will notify the affected individual no later than 60 days of discovering of the Breach.

BREACH NOTIFICATION

a. PeriGen will provide the following information to the Covered Entity for whose unsecured PHI has been, or is reasonably believed by the Covered Entity to have been, accessed, acquired, used, or disclosed as a result of such breach:

i. A brief description of what happened, including the date of the breach and the date of the discovery of the breach, if known.

ii. A description of the types of unsecured PHI that were involved in the breach (such as whether full name, social security number, date of birth, home address, account number, diagnosis, disability code, or other types of information were involved).

iii. Any steps individuals should take to protect themselves from potential harm resulting from the breach.

iv. A brief description of what the Business Associate is doing to investigate the breach, to mitigate harm to individuals, and to protect against any further breaches.

b. PeriGen will provide such information in plain language and by the methods set forth by HIPAA and state law.

c. The Privacy & Security Officer will retain all documentation regarding the Breach in accordance with the PeriGen Document Retention Policy (see Attachment A).

d. If the breach affects more than 500 residents of a state or jurisdiction area, in addition to notifying the affected individuals, PeriGen will provide notice to prominent media outlets serving the state or jurisdiction.

e. PeriGen may provide notice in the form of a press release, and the notice must be provided without unreasonable delay and in no case less than 60 days following the discovery of a breach and must include the same information as the individual notice listed above.

f. In all cases of a Breach, PeriGen will notify the Secretary via the HHS website. The Privacy & Security Officer will confer with outside counsel or consultants to ensure the notice to the Secretary is handled in the proper manner.

DISCIPLINARY ACTIONS

1. No Workforce Member who reports a suspected Breach that is caused by another Workforce Member will face retaliation from PeriGen.
2. Workforce Members who cause a Breach may be subject to disciplinary action.

Responsibility: Privacy & Security Officer

Definitions: Breach; ePHI; PHI; Workforce Member

Regulatory Category: Privacy Regulations

Regulatory Reference:

- ♦ 45 C.F.R. §164.404 Notification to Individuals
- ♦ 45 C.F.R. §164.410 Notification by a Business Associate

Reviewed By:

Approved By:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

HIPAA Privacy Rule Language:

(1) *Business Associate Contracts*

(i) The contract or other arrangement required by §164.502(e)(2) must meet the requirements of §164.502 (e)(2),(e)(3), or (e)(5) of this section, as applicable.

(ii) A covered entity is not in compliance with the standards of §164.502(e) of this paragraph, if the covered entity knew of a pattern of activity or practice of the business associate that constituted a material breach or violation of the business associate's obligation under the contract or other arrangement, unless the covered entity took reasonable steps to cure the breach or end the violation, as applicable, and if such steps were unsuccessful, terminated the contract or arrangement, if feasible.

(2) *Implementation specifications: Business associate contracts.* A contract between the covered entity and a business associate must:

(i) Establish the permitted and required uses and disclosures of protected health information by the business associate. The contract may not authorize the business associate to use or further disclose the information in a manner that would violate the requirements of this subpart, if done by the covered entity, except that:

(A) The contract may permit the business associate to use and disclose protected health information for the proper management and administration of the business associate; and

(B) The contract may permit the business associate to provide data aggregation services relating to the health care operations of the covered entity.

(ii) Provide that the business associate will:

(A) Not use or further disclose the information other than as permitted or required by the contract or as required by law;

(B) Use appropriate safeguards and comply, where applicable, with the Security Rule with respect to electronic protected health information, to prevent use or disclosure of the information other than as provided for by its contract;

(C) Report to the covered entity any use or disclosure of the information not provided for by its contract of which it becomes aware, including breaches of unsecured protected health information as required by § 164.410;

(D) In accordance with § 164.502(e)(1)(ii), ensure that any subcontractors that create, receive, maintain or transmit protected health information on behalf of the business associate agree to the same restrictions and conditions that apply to the business associate with respect to such information;

(E) Make available protected health information in accordance with §164.524;

(F) Make available protected health information for amendment and incorporate any amendments to protected health information in accordance with §164.526;

(G) Make available the information to provide an accounting of disclosures in accordance with §164.528;

(H) To the extent the business associate is to carry out a covered entity's obligation under this subpart, comply with the requirements of this subpart that apply to the covered entity in the performance of such obligation.

(I) Make its internal practices, books, and records relating to the use and disclosure of protected health information received from, or created or received by the business associate on behalf of, the covered entity available to the Secretary for purposes of determining the covered entity's compliance with this subpart; and

(J) At termination of the contract, if feasible, return or destroy all protected health information received from, or created or received by the business associate on behalf of, the covered entity that the business associate still maintains in any form and retain no copies of such information, or if such return or destruction is not feasible, extend the protections of the contract to the information and limit further uses and disclosures to those purposes that make the return or destruction of the information infeasible. 45 CFR § 164.504(e)

HIPAA Security Rule Language:

"A covered entity may permit a business associate to create, receive, maintain, or transmit electronic PHI on the covered entity's behalf only if the covered entity obtains satisfactory assurances, in accordance with § 164.316(a) (the Organizational Requirements) that the business associate will appropriately safeguard the information." 45 CFR § 164.308(b)(1).

"Document the satisfactory assurances required by paragraph (b)(1)of this section through a written contract or other arrangement with the business associate that meets the applicable requirements of § 164.314(a)." 45 CFR § 164.308(b)(3).

Purpose Statement: PeriGen shall comply with the Privacy and Security Rules regarding Business Associate Agreements and shall enter into a Business Associate Agreement with a Business Associate in advance of disclosing any PHI or ePHI or potential PHI. In any case where PeriGen acts a Business Associate under the HIPAA Privacy Regulations because it transmits, accesses, and/or maintains PHI or ePHI on behalf of another covered entity, it shall enter into a Business Associate Agreement with that Covered Entity in advance of receiving PHI or ePHI and enter into

a Business Associate Agreement with any subcontractor in advance of disclosing or transmitting any PHI or ePHI to that party.

Policy/Procedure:

BUSINESS ASSOCIATE AGREEMENTS WITH BUSINESS ASSOCIATES

1. PeriGen will enter into a Business Associate Agreement with each Business Associate with which it does business that causes the Business Associate to have access to, transmit or maintain PHI on behalf of PeriGen.

2. PeriGen will enter into a Business Associate Agreement with any subcontractor to which PeriGen intends to provide any PHI of that Covered Entity.

3. The Chief Financial Officer will be responsible for keeping a list of all Business Associates along with their contact information as well as a file containing all Business Associate Agreements signed by PeriGen. If the Chief Financial Officer or others in PeriGen's management cannot determine whether a vendor or other entity is a Business Associate, the Chief Financial Officer will consult with legal counsel in order to obtain advice regarding whether a Business Associate Agreement is required.

4. In the Business Associate Agreement, the Business Associate will acknowledge, among other things, that the Business Associate will appropriately safeguard ePHI and the ePHI Systems on which such information is stored and utilized through the implementation of its Security Policies and Procedures that fully comply with the HIPAA Security Regulations.

5. The Business Associate Agreement is provided below.

Responsibility: Chief Financial Officer

Definitions: ePHI; PHI; Business Associate; Covered Entity; Vendor

Regulatory Category: Administrative Safeguards

Regulatory Reference:

- 45 C.F.R. §§164.308(b)(1)-(b)(4), Business Associate Contracts and Other Arrangements [Standard; Required]
- 45 C.F.R. §164.314(a)
- 45 C.F.R. §164.502(e); 164.504(e), Uses and Disclosures of Protected Health Information: General Rules; Uses and Disclosures: Organizational Requirements

Exhibit: Business Associate Agreement (Business Associate), Business Associate Agreement (Covered Entity)

Reviewed By:

Approved By:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2017

HIPAA Business Associate Agreement

This HIPAA Business Associate Agreement ("Agreement") is entered into by and between _____ ("Customer") and PeriGen, Inc. ("PeriGen"). Customer and PeriGen are each a "Party" and collectively the "Parties".

The Parties agree to be bound by the following terms and conditions:

RECITALS:

WHEREAS the Customer is a "Covered Entity" and PeriGen is a "Business Associate," each respectively subject to the Administrative Simplification provisions of the Health Insurance Portability and Accountability Act of 1996 ("HIPAA"), as amended and supplemented by the HITECH Act, and the regulations promulgated pursuant to each, including the Standards for Privacy of Individually Identifiable Health Information and the Security Standards for the Protection of Electronic Health Information at 45 C.F.R. Parts 160 and 164. HIPAA, the HITECH Act, and the regulations promulgated pursuant to each shall collectively be referred to herein as "HIPAA." All references herein to "Covered Entity" shall mean the Customer. All references herein to "Business Associate" shall mean PeriGen.

WHEREAS PeriGen is a "Business Associate" and provides services to the Customer as set forth in an underlying license and/or services agreement between the parties ("Underlying Agreement") to which this Agreement is attached as an Exhibit.

WHEREAS, in the course of providing such services to the Customer, PeriGen may come into contact with Protected Health Information ("PHI") of individuals who are patients of the Customer.

WHEREAS, this Agreement shall remain in effect during the entire period the Agreement is in effect. In addition, portions of this Agreement shall remain in effect subsequent to the termination of the Underlying Agreement, as provided in this Agreement.

NOW THEREFORE, the Parties agree as follows:

1. Definitions

Terms used, but not otherwise defined, in this Agreement shall have the same meaning as those terms in HIPAA and in the Underlying Agreement.

2. Appointment of Business Associate

The Customer hereby appoints PeriGen as its Business Associate under HIPAA to assist in providing services in connection with the Parties' Underlying Agreement.

3. Obligations and Activities of Business Associate

a) Business Associate acknowledges that it shall provide services consistent with the Parties' Underlying Agreement.

b) Business Associate represents and warrants that it will comply with HIPAA, as amended. Business Associate agrees to not use or further disclose PHI other than as permitted or required by the Underlying Agreement, this Agreement or as Required by Law.
c) Business Associate agrees to use appropriate safeguards to prevent use or disclosure of the PHI consistent with the HIPAA Security Rule (45 C.F.R. Part 160 and Subpart C of 45 C.F.R. Part 164). These shall include the establishment and maintenance of appropriate administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of PHI (whether electronic or otherwise). Business Associate will follow generally accepted system security principles and comply with the requirements of HIPAA.
d) Business Associate agrees to mitigate, to the extent practicable, any harmful effect that is known to Business Associate of a use or disclosure of PHI by Business Associate or any of its employees, agents or subcontractors (as such term is defined by HIPAA, hereinafter, "Subcontractors") in violation of the requirements of this Agreement or HIPAA.
e) Business Associate agrees to report to Customer any use or disclosure of PHI not provided for by this Agreement of which Business Associate becomes aware, including breaches of unsecured PHI and Security Incidents ("Notifying Event"). Such report must be provided to Customer within ten (10) business days of Business Associate's discovery of such Notifying Event. Business Associate shall cooperate and coordinate with Customer to determine additional actions that may be required of Business Associate for mitigation of a Notifying Event. Business Associate otherwise agrees to comply with all requirements concerning breach notification as required by HIPAA.
f) Notwithstanding the foregoing, the parties agree to the following reporting procedure for Security Incidents that do not result in unauthorized access, use, disclosure, modification, destruction of Electronic Protected Health Information ("ePHI"), or interference with system operations ("Unsuccessful Security Incidents"). For Unsuccessful Security Incidents, the parties agree that this paragraph constitutes notice of such Unsuccessful Security Incidents. By way of example, the parties consider the following to be illustrative of Unsuccessful Security Incidents when they do not result in actual unauthorized access, use, disclosure, modification, destruction of ePHI, or interference with system operations: (i) pings on firewall; (ii) port scans; (iii) attempts to log on to a system or enter a database with an invalid password or username; (iv) denial-of-service attacks that do not result in a server being taken off-line; and (v) malware (worms, viruses, etc.).
g) Business Associate agrees to ensure that any agent, including a Subcontractor, to whom it provides PHI received from, or created or received by Business Associate on behalf of the Customer agree to the same restrictions and conditions that apply through this Agreement to Business Associate with respect to such information.
h) Business Associate agrees to provide access, at the request of the Customer, and in a reasonable time and manner, to PHI in a Designated Record Set, to the Customer or, as directed by the Customer, to an Individual in order to meet the requirements under 45 C.F.R. § 164.524. To the extent that such PHI is maintained in an Electronic Health Record, Business Associate agrees to produce a copy of such PHI in electronic format upon Customer's or a patient's request in accordance with HIPAA.
i) Business Associate agrees to make any amendment(s) to PHI in a Designated Record Set that the Customer directs or agrees to pursuant to 45 C.F.R. § 164.526 at the request of the Customer or an Individual, and in a reasonable time and manner.
j) Business Associate agrees to make internal Customers, books, and records relating to the use and disclosure of PHI received from, or created or received by Business Associate on behalf of, the Customer available to the Customer, or at the request of the Customer to the Secretary, in a reasonable time and manner, for purposes of the Secretary determining Customer's compliance with the Privacy Rule.
k) Business Associate agrees to document such disclosures of PHI and information related to such disclosures as would be required for the Customer to respond to a request by an Individual for an accounting of disclosures and to provide the Customer or an Individual, in a reasonable time and manner, information collected in accordance with this Agreement, to permit the Customer to respond to a request by an Individual for an accounting and disclosures of PHI in accordance with 45 C.F.R. § 164.528.
l) Business Associate agrees to restrict the use or disclosure of PHI to the minimum necessary, as required by HIPAA or requested by the Customer or an Individual, to accomplish the services and other obligations herein.
m) Business Associate agrees to comply with the prohibition on the sale of PHI without an Individual's authorization in accordance with HIPAA.
n) Business Associate agrees to comply with the restrictions on marketing set forth in HIPAA unless permitted by this Agreement and HIPAA.
o) To the extent that Business Associate is to carry out a Customer's obligation under Subpart E of 45 C.F.R. Part 164, Business Associate agrees to comply with the requirements of Subpart E that apply to the Customer in the performance of such obligation.

4. Permitted Uses and Disclosures by Business Associate

a) Except as otherwise limited in this Agreement, Business Associate may use or disclose PHI (i) as permitted in the Underlying Agreement or (ii) to perform functions, activities, or services for, or on behalf of, the Customer as

specified in the Underlying Agreement, provided that in all such cases such use or disclosure would not violate the HIPAA if done by the Customer.

b) Except as otherwise limited in this Agreement, Business Associate may use PHI for the proper management and administration of the Business Associate or to carry out the legal responsibilities of the Business Associate.
c) Except as otherwise limited in this Agreement, Business Associate may disclose PHI for the proper management and administration of the Business Associate, provided that disclosures are required by law, or Business Associate obtains reasonable assurances from the person to whom the information is disclosed that it will remain confidential and be used or further disclosed only as required by law or for the purpose for which it was disclosed to the person, and the person notifies the Business Associate of any instances of which it is aware in which the confidentiality of the information has been breached.
d) Except as otherwise limited in this Agreement, Business Associate may use PHI to provide data aggregation services as permitted by 45 C.F.R. § 164.504(e)(2)(i)(B).

5. Obligations of Customer

a) The Customer represents and warrants that it will comply with HIPAA as amended.
b) The Customer shall notify Business Associate of any limitations in its Notice of Privacy Customers to the extent that such limitation may affect Business Associate's use or disclosure of PHI.
c) The Customer shall provide Business Associate with any changes in, or revocation of, permission by Individual to use or disclose PHI, if such changes affect Business Associate's permitted or required uses and disclosures.
d) The Customer shall notify Business Associate of any restriction to the use or disclosure of PHI that Customer has agreed to in accordance with 45 C.F.R. § 164.522, to the extent that such restriction may affect Business Associate's use or disclosure of PHI.
e) The Customer shall provide Business Associate with a copy of its current Notice of Privacy Customers as required by 45 C.F.R. § 164.520 and will provide revised copies of the Notice should the Notice be amended in any way.

6. Permissible Requests by The Customer

The Customer shall not request Business Associate to use or disclose PHI in any manner that would not be permissible under the Privacy Rule if done by the Customer, except that the Business Associate may use or disclose PHI for data aggregation services in accordance with paragraph 4.(d), or management and administrative activities of Business Associate.

7. Term and Termination

a) Term. The Term of this Agreement shall be co-terminus with the Underlying Agreement. In addition, upon the Business Associate's or the Customer's ("Terminating Party") knowledge of a material breach by the other Party that is not curable, the Terminating Party may immediately terminate this Agreement. In the event that such breach is curable then the Terminating Party may immediately terminate this Agreement if such breach is not cured by the other Party within thirty (30) days of its receipt of written notice of the breach from the Terminating Party.
b) Continued Safeguard of Information. The Customer and Business Associate have mutually determined and agreed that return or destruction of the PHI created or received by Business Associate, its agents and Subcontractors, on behalf of Customer (including but not limited to that PHI contained in Business Associate's and its agents' and Subcontractors' data processing, data storage, and other computer systems): (i) is not feasible; and (ii) Business Associate and its agents and Subcontractors shall not be obligated to return or destroy such PHI. Notwithstanding the termination of this Agreement, Business Associate hereby agrees to extend (and to require its agents and Subcontractors to extend) the protections of this Agreement to such PHI to those purposes that make the return or destruction infeasible, for so long as Business Associate or its agents and Subcontractors maintain such PHI. This provision shall survive termination of this Agreement and the Underlying Agreement.

8. Miscellaneous

a) Regulatory References. A reference in this Agreement to a section in the Privacy Rule means the section as in effect or as amended, and for which compliance is required.
b) Amendment. The Parties acknowledge that state and federal laws relating to data security and privacy are evolving and that amendment of this Agreement may be required to ensure compliance with changes in the laws or regulations. The Parties specifically agree to take such action necessary to implement the standards and requirements of HIPAA or any other applicable federal or state privacy law or regulation relating to the security or privacy of information, or the exchange of health information by electronic means. Upon the effective date of any final regulation or amendment to HIPAA and any applicable state privacy law or regulation, and any implementing regulations issued by any regulatory authority having jurisdiction, this Agreement will

automatically be amended such that the obligations they impose (or require the Customer to impose) on Business Associate will be deemed included in this without further action of the Parties, effective as of the required compliance date of such regulation or amendment.

c) Interpretation. Any ambiguity in this Agreement shall be resolved in favor of a meaning that permits the Customer and Business Associate to comply with the Privacy and/or Security Rule.

d) No Third Party Beneficiary Rights. Nothing express or implied in this Agreement is intended to give, nor shall anything herein give any person other than the Parties and the respective successors or assigns of the Parties, any rights, remedies, obligations, or liabilities whatsoever.

e) Entire Agreement. This Agreement along with the Underlying Agreement sets for the forth the entire agreement and understanding between the Parties as to the subject matter hereof and supersedes all prior discussions, agreements and understandings relating to such subject matter. This Agreement is incorporated into and made a part of the Underlying Agreement as an exhibit thereto.

CUSTOMER: _____

Signature: _____

By: _____

Title: _____

Date: _____

PERIGEN, INC.

Signature: _____

By: _____

Title: _____

Date: _____

HIPAA Privacy Rule Language: "When using or disclosing protected health information or when requesting protected health information from another covered entity or business associate, a covered entity…must make reasonable efforts to limit protected health information to the minimum necessary to accomplish the intended purpose of the use, disclosure or request." 45 C.F.R. § 164.502(b).

"A covered entity must identify: (A) those persons or classes of persons, as appropriate, in its workforce who need access to protected health information to carry out their duties; and (B) For each such person or class of persons, the category or categories of protected health information to which access is needed and any conditions appropriate to such access…A covered entity must make reasonable efforts to limit the access of such persons or classes…to protected health information[for which access is necessary].

"For any type of disclosure it makes on a routine or recurring basis, a covered entity must implement policies and procedures (which may be standard protocols) that limit the protected health information disclosed to the amount reasonably necessary to achieve the purpose of the disclosure.

For all other disclosures, a covered entity must: (A) develop criteria designed to limit the protected health information disclosed to the information reasonably necessary to accomplish the purpose for which disclosure is sought; and (B) review requests for disclosure on an individual basis in accordance with such criteria."

"A covered entity must limit any request for protected health information to that which is reasonably necessary to accomplish the purpose for which the request is made, when requesting such information from other covered entities.

For a request that is made on a routine and recurring basis, a covered entity must implement policies and procedures (which may be standard protocols) that limit the protected health information requested to the amount reasonably necessary to accomplish the purpose for which the request is made.

For all other requests, a covered entity must: (A) development criteria designed to limit the request for protected health information to the information reasonably necessary to accomplish the purpose for which the request is made; and (B) review requests for disclosure on an individual basis in accordance with such criteria." 45 CFR § 164.514(d).

Purpose Statement: PeriGen will use reasonable efforts to limit any authorized use or disclosure of PHI or ePHI to the least amount necessary (the "minimum necessary") to accomplish the intended purpose of the disclosure. This policy encompasses PHI in any format, such as oral, electronic, or written.

Policy/Procedure:

PeriGen will limit all uses and disclosures of or requests for PHI to the minimum necessary to achieve the purpose of the use, disclosure or request, except for:

a. Disclosures to or requests by a healthcare provider for treatment purposes
b. Uses or disclosures made to an individual for his or her PHI
c. Uses or disclosures made pursuant to an authorization from an individual
d. Disclosures made to the Secretary of Health and Human Services
e. Uses or disclosures required by law
f. Uses or disclosures required for compliance with HIPAA

INTERNAL USES

1. The Privacy & Security Officer will assess and determine, on a yearly basis, those Workforce Members who require access to PHI in order to carry out their job functions.
2. PeriGen will document its Workforce Members' access to PHI.
3. The Privacy & Security Officer will ensure that reasonable efforts are used to limit the access to the persons identified and for only the types of PHI, which are needed to carry out their job functions.
4. For PHI that PeriGen uses to perform certain management and administrative functions, PeriGen will limit all uses of PHI to the minimum necessary to achieve the purpose of the particular management or administrative function.

DISCLOSURES

1. For any disclosure that PeriGen requests or makes on a routine and recurring basis, PeriGen will implement protocols that establish the minimum necessary amount of PHI that may be disclosed to achieve the purpose of the disclosure. On an annual basis, the Privacy & Security Officer will:
   a. Assess and determine all routine and recurring disclosures requested or made by PeriGen.
   b. Compose and complete a disclosure survey that identifies all routine and recurring disclosures.
   c. Assess and determine the types of PHI that are disclosed for the disclosures identified on the disclosure survey.
   d. For all recurring disclosures identified in the disclosure survey, the Privacy & Security Officer will document any parameters relevant to ensuring that the PHI disclosed will be limited to the amount reasonably necessary to achieve the purpose of the disclosure, but each disclosure does not require independent review by the Privacy & Security Officer.
2. For all disclosures not specifically listed on the annual disclosure survey, the disclosure request must be sent to the Privacy & Security Officer for review and determination for compliance with the minimum necessary standard.
3. The following disclosures do not have to be reviewed by the Privacy & Security Officer for determination, and any such request will be deemed to be the minimum necessary for the requested disclosure:

a. Disclosures made to public officials as required by or in accordance with the law, if the public official represents that the information requested is the minimum necessary for the stated purpose(s);
b. A professional who is a Workforce Member or Business Associate who represents that the information requested is the minimum necessary for stated purposes and who requests the information for the purpose of providing professional services to the Facility; or
c. Information requested by the Covered Entity for either treatment, payment, or healthcare operations purposes.

Responsibility: Privacy & Security Officer

Definitions: Covered Entity; ePHI; PHI

Regulatory Reference:

- 45 C.F.R. § 164.502(b), Uses and Disclosures of Protected Health Information: General Rules; Standard: Minimum Necessary
- 45 C.F.R. §164.514(d), Other Requirements Relating to Uses and Disclosures of PHI: Minimum Necessary Requirements

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

HIPAA Privacy Rule Language: "A covered entity may use protected health information to create information that is not individually identifiable health information or disclose protected health information only to a business associate for such purpose, whether or not the de-identified information is to be used by the covered entity.

Health information that meets the standard and implementation specifications for de-identification under § 164.514(a) and (b) is considered not to be individually identifiable health information, i.e., de-identified. The requirements of this subpart do not apply to information that has been deidentified in accordance with the applicable requirements of § 164.514, provided that: (i) disclosure of a code or other means of record identification designed to enable coded or otherwise de-identified information to be re-identified constitutes disclosure of protected health information; and (ii) if de-identified information is re-identified, a covered entity may use or disclose such reidentified data only as permitted or required by this subpart." 45 C.F.R. § 164.502(d).

Health information that does not identify an individual and with respect to which there is no reasonable basis to believe that the information can be used to identify an individual is not individually identifiable health information. 45 CFR § 164.514(a).

Purpose Statement: PeriGen may use and disclose an individual's health information that has been de-identified. After health information is de-identified, it is no longer subject to the requirements of the HIPAA Privacy Regulations.

Policy/Procedure:

1. All de-identification of PHI will be performed at the direction and under the supervision of the Director of Quality and Regulatory or PeriGen's outside counsel in accordance with PeriGen's Covered Entity, if applicable.
2. The reason for the de-identification will be documented and maintained by the Director of Quality and Regulatory.
3. PeriGen may de-identify an individual's health information in either of the following ways:
    a. Removing each of the following 18 identifiers of the individual, or his/her relatives, employers or household members from the relevant document:
        i. Names
        ii. All geographic subdivisions smaller than a state, including street address, city, county, precinct, zip code, and their equivalent geocodes. The first three digits of a zip code may only be included in certain limited circumstances in accordance with 45 CFR 164.514.
        iii. All elements of dates (except year) for dates directly related to an individual, including birth date, admission date, discharge date, date of death, and all ages over 89 and all elements of dates (including year) indicative of such age, except that such ages and elements may

be aggregated into a single category of age 90 or older. iv. Telephone numbers.

v. Fax numbers.

vi. Social Security numbers. vii. Electronic mail address. viii. Medical record numbers.

vii. Health plan beneficiary numbers.

viii. Account numbers.

ix. Certificate/license numbers.

xii. Vehicle identifiers and serial numbers, including license plate numbers.

xiii. Device identifiers and serial numbers.

xiv. Web Universal Resource Locators (URLs).

xv. Internet Protocol (IP) address numbers.

xvi. Biometric identifiers, including finger and voiceprints.

xvii. Full face photographic images and any comparable images.

xviii. Any other unique identifying number, characteristic, or code, except for codes assigned to an individual but generated from information not related to the individual, as permitted for reidentification.

b. If any of the above 18 identifiers are not removed, PeriGen may utilize a qualified person to determine that the risk is very small that the information could be used, either by itself or in combination with other available information, by anticipated recipients to identify a subject of the information.

i. A "qualified person" is a person:

1. with appropriate knowledge and experience applying generally accepted statistical and scientific principles and methods for rendering information not individually identifiable;

2. who applies such methods and principles to determine that the risk is very small that the information could be used, alone or in combination with other reasonably available information, by an anticipated recipient to identify an individual who is a subject of the information; and

3. who documents the methods and results of the analysis that justify such determination.

4. No de-identified information will be disclosed if PeriGen has knowledge that the information could be used alone or in combination to identify a subject of the information. To the extent that PeriGen generates any permitted codes for reidentification of deidentified data, PeriGen will keep such codes confidential and limit access to only those Workforce Members who require such codes to fulfill their duties.

Responsibility: Privacy & Security Officer, Director of Quality and Regulatory

Definitions: PHI

Regulatory Reference:

♦ 45 C.F.R. § 164.502(d); Standard: Uses and Disclosures of De-Identified Protected Health Information.

♦ 45 C.F.R. §164.514(a)-(c), De-Identification.

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Privacy	Procedure No.: 14
Title: Facsimiles	**Revision: 1.0**	**Effective Date**

Purpose Statement: To protect the confidentiality and integrity of PHI under the HIPAA Privacy Regulations, all Workforce Members who fax PHI must use extreme caution to make sure that only the correct information is faxed and that the information is faxed to the proper party.

Policy/Procedure:

1. Workforce Members must be aware of the fact that faxes can be intercepted and that faxes can be sent to the wrong party - either by misdialing or receiving an incorrect fax number from the intended recipient. Therefore, Workforce Members must adhere to the following procedures when faxing PHI:
   a. Limit faxing to urgent or non-routine incidents when other delivery options are not available, except in instances where faxing is required.
   b. Schedule a fax delivery time with the recipient to make sure that the fax is received by the intended recipient, and, if feasible, call the recipient within a reasonable time after submitting the fax to confirm that the intended recipient did receive the fax.
   c. All faxes must contain a cover sheet that does not disclose PHI.
2. Faxes sent to PeriGen Workforce Members will be delivered through a secure email service. With this delivery system, there would not be circumstances in which faxes would ever be printed out of the traditional fax machine.
3. All fax machines will be located in physically secure areas.

Responsibility: Privacy & Security Officer

Definitions: PHI; Workforce Member

Regulatory Reference:

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

HIPAA Privacy Rule Language: "A covered entity must designate a privacy official who is responsible for the development and implementation of the policies and procedures of the entity." 45 C.F.R. §164.530(a)

Purpose Statement: PeriGen will install a Privacy & Security Officer who will be responsible for the implementation and day-to-day administration and oversight of PeriGen's compliance with the HIPAA Privacy Regulations. The Privacy & Security Officer will also develop Workforce Training programs in conjunction with the Human Resource Office and the Director of Quality and Regulatory regarding the privacy of PHI, update and implement of these Privacy Policies and Procedures, and serve as the designated decision-maker for issues and questions involving interpretation of the HIPAA Privacy Regulations. The PeriGen Privacy & Security Officer will be assisted by the Director of Quality & Regulatory, Chief Product Officer, Director, Technical Client Services and Remote Operations, Human Resource Manager, Chief Financial Officer, and others on a daily basis or as often as needed.

Policy/Procedure:

1. The Privacy & Security Officer is responsible for the following tasks:
   a. Inventorying the uses and disclosures of all PHI;
   b. Ensuring that legal issues in drafting compliance documents are addressed or engage competent legal counsel to draft such documents;
   c. Administering sanctions upon Workforce Members for violations of these Privacy Policies and Procedures;
   d. Developing, updating, and revising these Privacy Policies and Procedures as necessary to comply with the HIPAA Privacy Regulations;
   e. Developing a privacy training program;
   f. Establishing procedures to monitor internal privacy compliance;
   g. Keeping up to date on the latest privacy developments and federal and state laws and regulations;
   h. Serving as PeriGen's liaison to regulatory bodies for matters relating to privacy;
   i. Coordinating any audits by the Secretary of HHS or any other governmental or accrediting organization regarding PeriGen's compliance with state or federal privacy laws or regulations; and
   j. Other tasks that are necessary to ensure the privacy of PHI.

2. PeriGen's Privacy & Security Officer's name and contact information is:

   Name: Bruno Bendavid
   Email: Bruno.bendavid@PeriGen.com
   Phone (work):

Responsibility: PeriGen Management

Definitions:

Regulatory Category: Privacy Regulations

Regulatory Reference:

- ♦ 45 C.F.R. §164.530(a), Personnel Designations [Standard; Required]

Reviewed By: Bruno Bendavid

Approved By: Brian Bishop

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 16
Title: Security Analysis and Risk Management	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: "A covered entity must implement policies and procedure to prevent, detect, contain, and correct security violations. 45 CFR § 164.308 (a)(1)(i).

Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the covered entity…

Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with 45 CFR § 164.306(a)." 45 CFR § 164.308 (a)(1)(ii)(A) and (B).

Purpose Statement: PeriGen, under the HIPAA Security Regulations, is required to implement a security management process and to undertake a risk analysis. Implementation of this security management process will assist PeriGen in ensuring the confidentiality, integrity, and availability of ePHI. PeriGen will create and maintain appropriate and reasonable policies, procedures, and controls to prevent, detect, contain, and correct security violations.

Policy/Procedure:

RISK ANALYSIS

1. At least once per year, PeriGen will convene a workgroup and/or engage outside assistance to conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI and ePHI Systems accessed, used by, owned or operated by PeriGen.
2. The workgroup will consider:
    a. Potential security risks to each ePHI System, including those Security Incidents specifically identified in the Security Incident and Response Policy;
    b. The probability of the occurrence of risks that may affect PeriGen's ePHI through use of effective Threat intelligence;
    c. The magnitude of the identified risk to each ePHI System, workforce member, policy or platform
    d. The criticality of each ePHI System to PeriGen's operations during or after an emergency or disaster;
    e. The frequency of reviews and audits of PeriGen's ePHI Systems pursuant to the Information System Activity Review Policy;
    f. The training and the frequency of such training, to be offered to PeriGen's Workforce Members regarding the security of ePHI;
    g. The need to do penetration testing of the security of PeriGen's ePHI Systems; and
    h. The need to engage third parties to evaluate the risks and vulnerabilities (penetration testing) to the ePHI Systems.

RISK MANAGEMENT

1. In an effort to reduce risks and vulnerabilities to ePHI contained within its ePHI Systems, PeriGen will create a Risk Management Plan to address risks identified in the annual Risk Analysis.
2. In addition to updating the Risk Management Plan after each Risk Analysis, the Privacy & Security Officer will also update the Plan:
   a. After any Security Incident to minimize the likelihood of a similar Security Incident occurring in the future;
   b. After a new functionality or use is added to any ePHI System; and PeriGen's Workforce Members
   c. In response to the addition of any new ePHI System.
3. In developing each Risk Management Plan, PeriGen will consider the following:
   a. The security measures that are already in place to address the risk;
   b. Additional security measures that can reasonably and appropriately be put in place to address the risk;
   c. Communication of the security measures and Risk Management Plan to PeriGen's Workforce Members; and
   d. The need to engage other resources to assist in the implementation of the Risk Management Plan.

Responsibility: Privacy & Security Officer;

Definitions: Administrative Safeguards; ePHI System; ; Workforce Member;

Regulatory Reference:

- ♦ 45 C.F.R. §164.308(a)(1)(i), Security Management Process [Standard; Required]
- ♦ 45 C.F.R. §164.308(a)(1)(ii)(A), Risk Analysis [Implementation Specification; Required]
- ♦ 45 C.F.R. §164.308(a)(1)(ii)(B), Risk Management [Implementation Specification; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 17
Title: Information System Activity Review; Audit Controls	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports. 45 CFR § 164.308(a)(1)(ii)(D).

"Implement hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use electronic protected health information." 45 CFR § 164.312(b)

Purpose Statement: PeriGen will - to the extent technically feasible and necessary to guard against identified risks to ePHI – implement hardware, software, and/or procedural mechanisms that record and examine activity in its ePHI Systems to enable PeriGen to detect potentially problematic activity in its ePHI Systems. These audit controls will allow PeriGen to:

1. Identify questionable data access activities in ePHI Systems;
2. Investigate Breaches;
3. Respond to potential weaknesses in ePHI Systems' architecture; and
4. Assess the effectiveness of PeriGen's Security Policies and Procedures.

Policy/Procedure:

<u>AUDIT LOGS</u>

1. The following activity audit logs may be generated and reviewed:
    a. Failed authentication attempts after a three (3) unsuccessful attempts;
    b. Automatic sign-offs;
    c. Records contained in each ePHI System, which are accessed by Workforce Members ; and/or
    d. Additions, deletions, or other modifications made to records contained within each ePHI System.
2. The ePHI System activity auditing mechanisms may generate the following information for each audit log:
    a. Date and time of activity;
    b. Descriptions of each attempted or completed activity;
    c. Identification of the Workforce Member performing the activity; and/or
    d. Origin of the activity, such as the I/P address or workstation identification number.

FREQUENCY OF INFORMATION SYSTEM ACTIVITY REVIEW

1. PeriGen will use its findings from the risk analysis to help determine the frequency of its activity review of each ePHI System.
2. PeriGen will consider the following factors with respect to the frequency of audits and activity reviews:
   a. The sensitivity of the ePHI contained within each particular ePHI System; and
   b. The degree to which each ePHI System is connected to other systems, either within or outside of PeriGen, that contain ePHI and the degree to which that connection poses a risk the ePHI.
3. PeriGen will identify and document the names of Workforce Members who will review audit logs.
4. PeriGen will retain any audit logs that it creates for six (6) years after the date they are created.

IDENTIFICATION OF INAPPROPRIATE ACTIVITY

1. As patterns are identified and anomalous behavior becomes more apparent, PeriGen may establish thresholds for each audit report. The thresholds will signify the level at which certain behavior warrants further inspection and may signal a Security Incident or failure to comply with PeriGen's policies and procedures. As thresholds are established, this policy will be revised accordingly.
2. If Security Incidents are identified through the audit logs, they must be brought to the attention of the Privacy & Security Officer, pursuant to the PeriGen Security Incident Management Policy.
3. If the audit logs reveal that a Workforce Member failed to comply with PeriGen's policies and procedures, appropriate sanctions may be imposed upon the Workforce Member pursuant to the PeriGen Workforce Member Discipline Policy.

Responsibility: Privacy & Security Officer; Director of Quality and Regulatory

Definitions: ePHI System; ePHI; Workforce Member; Security Incident;

Regulatory Reference:

- 45 C.F.R. §164308(a)(1)(ii)(D), Information System Activity Review [Implementation Specification; Required]
- 45 C.F.R. §164.312(b), Audit Controls [Standard; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1,0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 18
Title: E-mail Audit Policy	**Revision 1.0**	**Effective Date**

Purpose: To provide reasonable monitoring of outgoing ePHI from all staff workforce members. To document, report and analyze any findings of ePHI that was sent in an unsecure fashion.

Provisions of Policy:

A. Frequency:

i. Audit will be conducted every 6 months.
ii. Audit will include emails from within the *90 day* time period prior to the date of selected audit start date.

B. Sample size: 30 emails (15 with attachments; 15 without attachments)

C. Audit parameters:

i. 15 random outgoing messages with attachments – look to see if attachments contain PHI **AND**;

ii. 15 out box emails with no attachments- look to see if text contains ePHI.

iii. Document any findings of emails (with or without attachments) that had ePHI sent in an unsecure fashion.

****Outgoing message parameters are subject to change and may have different parameters each audit that are specifically relevant to a workforce member's job description.****

Options that may be selected include but are not limited to:

i. Emails sent to external distribution list
ii. Emails sent to PeriGen internal distribution groups
iii. Any outbox message (external and/or internal emails)

D. Findings:

i. All findings will be recorded on an audit log. Details of any found violation will be documented with the incident date, person(s) involved and a description of the incident. For reference purposes, a copy of the email containing the incident will be printed and stored in a secure location with the printed copy of the audit summary.
ii. All audit findings will be reviewed with the Privacy & Security Officer as well as with the Chief Product Officer.
iii. An audit summary sheet will be signed by the Director of Quality & Regulatory, the Privacy & Security Officer as well as the Chief Product Officer to document the completion of the audit review.

iv. Workforce members will receive an overview of their audit findings to address any incidents that were found and provide education where needed.
v. All audit findings will be stored accordingly in conjunction with the Practice's "Document Retention Policy" (see Attachment A).

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 19
Title: Assigned Security Responsibility	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: "Identify the security official who is responsible for the development and implementation of the policies and procedures required by this subpart for the entity..." 45 CFR § 164.308(a)(2).

Purpose Statement: Under the HIPAA Security Regulations and the HITECH Act, PeriGen is required to designate a Security Official who is responsible for the development and implementation of its Security Policies and Procedures. This policy reflects PeriGen's commitment to comply with such regulations. In addition, the appointment of the Privacy & Security Officer will provide organizational focus to, and highlight the importance of, PeriGen's efforts to protect the confidentiality, privacy and security of the ePHI and ePHI Systems to which is has access. The PeriGen Privacy & Security Officer will be assisted by the Director of Quality & Regulatory, Chief Product Officer, Director, Technical Client Services and Remote Operations, Human Resource Manager, Chief Financial Officer, and others on a daily basis or as often as needed.

Policy/Procedure:

1. The Privacy & Security Officer will perform the following duties, including taking all reasonable and appropriate measures to:
    a. Ensure and confirm that PeriGen is compliant with applicable federal, state, and local laws pertaining to the security of ePHI;
    b. Guide the development, documentation, and dissemination of appropriate security policies and procedures for the Workforce Members, and administrators of PeriGen's ePHI Systems;
    c. Ensure that newly acquired ePHI Systems have options that support required and/or addressable implementations of the HIPAA Security Regulations and PeriGen's internal security requirements;
    d. Approve and oversee the administration, implementation, and selection of PeriGen's security controls for ePHI Systems;
    e. Implement and oversee the security training of PeriGen's Workforce Members, and ensure that Workforce Members receive such training on a periodic basis as deemed necessary pursuant to PeriGen's Security Risk Management Policy, with the assistance of the Human Resources Office and the Director of Quality and Regulatory;
    f. Facilitate the yearly Risk Analysis and creation of a Risk Management Plan;
    g. Ensure that ePHI System activity is monitored and audited to identify Security Incidents and malicious activity as set forth in the Information System Activity Review Policy;
    h. Ensure that the threats and risks to the confidentiality, integrity, and availability of ePHI are monitored and evaluated; and
    i. Oversee the development and implementation of an effective Security Incident response policy and related procedures as set forth in PeriGen's Security Incident Management and Response Policy.

2. PeriGen's Information Security Official is:
   Name: Bruno Bendavid
   Email: Bruno.bendavid@PeriGen.com
   Phone (work):

Responsibility: The Privacy & Security Officer

Definitions: Security Incident

Regulatory Reference:

- ♦ 45 C.F.R. §164.308(a)(2), Assigned Security Responsibility [Standard; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

HIPAA Security Rule Language: "Implement policies and procedures to ensure that all members of its workforce have appropriate access to electronic PHI, as provided under paragraph (a)(4) [information access management] of this section, and to prevent those workforce members who do not have access under paragraph (a)(4) of this section from obtaining access to electronic PHI." 45 CFR § 164.308(3)(1).

"Implement procedures for the authorization and/or supervision of workforce members who work with electronic protected health information or in locations where it might be accessed.

Implement procedures to determine that the access of a workforce member to electronic protected health information is appropriate." §164.308(a)(3)(ii)(A)-(B).

Purpose Statement: To protect the confidentiality, integrity, and availability of ePHI, PeriGen will implement reasonable and appropriate safeguards to prevent unauthorized access to ePHI while ensuring that properly authorized Workforce Members' access to ePHI is permitted and where necessary, terminated.

Policy/Procedure:

WORKFORCE CLEARANCE

1. Security privileges will be identified and defined for each Workforce Member who is granted access to ePHI or ePHI Systems.
2. Based on the level of privileges to be granted to candidates for employment, or other arrangement, Human Resources personnel will perform appropriate and reasonable verifications checks on the candidate.
3. Verification checks may include, but are not limited to:
   a. Character references;
   b. Confirmation of claimed academic and professional qualifications; or
   c. Criminal background checks.
4. Upon accepting an offer of employment or other arrangement, each Workforce Member who will have access to ePHI will sign the Workforce Member HIPAA Compliance and Confidentiality Statement as required pursuant to the PeriGen Workforce Member Compliance Policy.

SUPERVISION OF WORKFORCE MEMBERS

1. The Privacy & Security Officer will take reasonable and appropriate steps to ensure that Workforce Members who have the ability to access ePHI or those who work in areas where ePHI might be accessed will be properly supervised. PeriGen will ensure that Workforce Members only access such ePHI that they are authorized to access pursuant to their job responsibilities.
2. PeriGen will ensure that appropriate sanctions are taken against Workforce Members who improperly access ePHI, or who inappropriately grant access to ePHI

to other Workforce Members. Sanctions will be instituted in accordance with the PeriGen Workforce Member Discipline Policy.

ACCESS TO ePHI

PeriGen will authorize, establish and modify, as appropriate, each Workforce Member's access to ePHI in accordance with the PeriGen Information Access Management Policy.

TERMINATION OF ACCESS TO EPHI

PeriGen will terminate a Workforce Member's access to ePHI, either in the event of a Workforce Member's resignation or a Workforce Member's termination by PeriGen, in accordance with the PeriGen Termination Procedures Policy.

Responsibility: Privacy & Security Officer; Human Resource Manager

Definitions: Workforce Member; ePHI System; ePHI

Regulatory Reference:

- 45 C.F.R. §164.308(a)(3)(i), Workforce Security [Standard; Required]
- 45 C.F.R. §164.308(a)(3)(ii)(A), Authorization and/or Supervision [Implementation Specification; Addressable]
- 45 C.F.R. §164.308(a)(3)(ii)(B), Workforce Clearance Procedure [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 21
Title: Information Access Management	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: Implement policies and procedures for authorizing access to electronic PHI that are consistent with the applicable requirements of [the Privacy Rule]" 45 CFR § 164.308(a)(4)(i).

"Implement policies and procedures for granting access to electronic protected health information, for example, through access to a workstation, transaction, program, process or other mechanism.

Implement policies and procedures that, based on the covered entity's…access authorization policies, establish, document, review, and modify a user's right of access to a workstation, transaction, program, or process." 45 CFR § 164.308(a)(4)(ii)(B)-(C).

Purpose Statement: PeriGen strives to protect the confidentiality, integrity, and availability of ePHI by taking reasonable steps to appropriately manage access to ePHI. Safeguarding access to ePHI contained within ePHI Systems is integral to PeriGen's compliance efforts under the HIPAA Security Regulations. This policy reflects PeriGen's commitment to comply with such Regulations by taking reasonable and appropriate steps to manage access to ePHI.

Policy/Procedure:

ESTABLISHING ACCESS TO ePHI

1. PeriGen will ensure that only authorized Workforce Members will have access to ePHI.
2. PeriGen will document the various levels of access to ePHI contained within its ePHI Systems that each Workforce Member will have based upon the job function requirements of each position.
3. Workforce Members will not be granted access to ePHI until the Workforce Member has been properly cleared in accordance with the PeriGen Workforce

Member Security Policy or the Business Associate Agreement Policy, respectively. Further, Workforce Members must not attempt to access ePHI until they are properly cleared.

4. Once a Workforce Member has completed privacy and security training, the Director, Technical Client Services and Remote Operations will assign the Workforce Member a unique username and password to activate access to ePHI.

REVIEW OF WORKFORCE MEMBERS' ACCESS TO ePHI

1. PeriGen will review access privileges to ePHI annually.
2. PeriGen may modify, if necessary, access privileges to ePHI.

MODIFICATION OF WORKFORCE MEMBERS' ACCESS TO ePHI

1. When a Workforce Member's access to ePHI must be modified, either because of a change in job function or termination, PeriGen will document such modifications.
2. Such documentation may include:

a. The date and time of the modification;
b. The identification of the Workforce Member whose access is being modified;
c. A description of the Workforce Member's modified access rights; and
d. The reason for the modification of the Workforce Member's access rights.

Responsibility: Privacy & Security Officer; Director of Quality and Regulatory; Human Resources Office; Director, Technical Client Services and Remote Operations

Definitions: Workforce Member

Regulatory Reference:

- 45 C.F.R. §164.308(a)(4)(i), Information Access Management [Standard; Required]
- 45 C.F.R. §164.308(a)(4)(ii)(B), Access Authorization [Implementation Specification; Addressable]
- 45 C.F.R. §164.308(a)(4)(ii)(C), Access Establishment and Modification [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

HIPAA Security Rule Language: Implement procedures for terminating access to electronic PHI when the employment of a workforce member ends or as required by determinations as specified in paragraph (a)(3)(ii)(B [workforce clearance] of this section. 45 CFR §164.308(a)(3)(ii)(C).

Purpose Statement: When a Workforce Member's employment or other arrangement with PeriGen ends or the Workforce Member's access to ePHI is no longer appropriate, PeriGen will terminate the Workforce Member's access to ePHI.

Policy/Procedure:

TERMINATION PROCEDURES UPON A WORKFORCE MEMBER'S RESIGNATION

1. When a Workforce Member provides notice of his or her intention to end his/her employment or other arrangement with PeriGen, the Human Resources Office will give reasonable notice to the Director of Quality and Regulatory as well as the PeriGen Information Technology Vendor, so that the departing Workforce Member's access to the applicable ePHI System can be terminated when he or she ends employment or his or her other arrangement.

TERMINATION PROCEDURES UPON A WORKFORCE MEMBER'S TERMINATION BY PeriGen

1. When Workforce Members are terminated, PeriGen will immediately remove or disable the Workforce Member's access privileges to the applicable ePHI System(s) before the Workforce Member is notified of his or her termination, when feasible.
2. Such ePHI System access privileges include, but are not limited to:
    a. Workstations and server access;
    b. Data access, particularly access to data contained within the applicable ePHI System(s);
    c. Access to any network that PeriGen uses;
    d. Email accounts; and/or
    e. Inclusion on group email lists.

GENERAL RESIGNATION AND TERMINATION PROCEDURES

1. PeriGen will terminate, as appropriate, a departing or terminated Workforce Member's physical access to areas where ePHI is located within PeriGen's facilities.
2. PeriGen will collect, and document the collection of, equipment and property that contains ePHI, which were used by the terminated or departing Workforce Member.
    a. Such documentation will include:
        i. The Workforce Member's name;
        ii. The date and time the equipment and property were returned; and

iii. The identification of the returned property and equipment.

b. PeriGen will securely maintain such documentation.

3. Equipment that may contain, allow, or enable the Workforce Member to access ePHI, and which must be returned upon the Workforce Member's termination or departure, include, but is not limited to: a. Portable computers;
   b. Personal Digital Assistants (PDAs);
   c. Name tags or name identification badges;
   d. Security tokens;
   e. Facility access cards; and or/
   f. Building, desk, or office keys.

In addition to these steps, a checklist for termination procedures for a Workforce Member is attached as "Workforce Member Exit Procedures" to this policy. A copy of "Workforce Member Exit Procedures" will be placed in the Workforce Member's file to acknowledge completion of the termination checklist.

Responsibility: Privacy & Security Officer; Director of Quality and Regulatory; Human Resources Office

Definitions: Workforce Member; ePHI; ePHI System

Regulatory Reference:

- 45 C.F.R. §164.308(a)(3)(ii)(C), Termination Procedures [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 23
Title: Security Reminders	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: "Implement periodic security updates."45 CFR § 164.308(a)(5)(ii)(A).

Purpose Statement: PeriGen has the responsibility under the HIPAA Security Regulations to implement periodic security updates for PeriGen Workforce Members in order that those persons can properly carry out their functions while appropriately safeguarding ePHI. This policy reflects PeriGen's commitment to comply with such Regulations.

Policy/Procedure:

1. PeriGen's Privacy & Security Officer will periodically, as needed, issue security information and awareness reminders to Workforce Members. Such security reminders could include:
   a. Information regarding general security risks and how to follow PeriGen's HIPAA Security Policies and Procedures;
   b. Information regarding how to use the applicable ePHI System(s) in a manner that reduces security risks; and/or
   c. Legal and business responsibilities of PeriGen for protecting its ePHI Systems.
2. PeriGen will issue security reminders immediately upon, or within a 30 day following the occurrence of any of the following events:
   a. Substantial revisions are made to PeriGen's Security Policies and Procedures;
   b. Substantial new security controls are implemented, or significant changes are made to existing security controls;
   c. Substantial changes are made to PeriGen's legal or business responsibilities;
   d. Substantial threats or risks arise against any ePHI System;
   e. PeriGen introduces a new ePHI System or makes significant changes to existing ePHI Systems that it owns or controls; or,
   f. An ePHI System to which PeriGen has access but no control over makes a significant change to its system.
3. Means of providing security information and awareness reminders and updates may include, but are not limited to:
   a. Email reminders;
   b. Posters;
   c. Letters;
   d. Workforce Member meetings;
   e. Information system sign-on messages;
   f. Internal newsletter articles; and/or

g. Information posted to PeriGen's external (i.e. public website) and/or internal website (i.e. SharePoint).

Responsibility: Privacy & Security Officer

Definitions: Workforce Member; ePHI; ePHI System

Regulatory Reference:

- 45 C.F.R. §164.308(a)(5)(ii)(A), Security Reminders [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 24
Title: Malicious Software	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: "Implement procedures for guarding against, detecting, and reporting malicious software." 45 CFR § 164.308(a)(5)(ii)(B).

Purpose Statement: PeriGen will implement and periodically review its process and implemented safeguards for guarding against, detecting, and reporting malicious software that pose risks to ePHI or ePHI Systems.

Policy/Procedure:

1. PeriGen will take all necessary and reasonable measures to protect its ePHI Systems, and all media upon which ePHI is contained, from malicious software, including:
   a. Ensuring that anti-virus software is installed on all media devices and hardware, either owned by or used by PeriGen, containing ePHI or which have access to ePHI Systems;
   b. Requiring all Workforce Members to scan email attachments and downloads before they are opened.
2. PeriGen, through its IT vendor, will conduct a weekly virus scan of its network server and workstations.
3. PeriGen Workforce Members must not bypass or disable anti-virus software installed on workstations unless they are properly authorized to do so.
4. PeriGen will provide annual training and awareness to Workforce Members about guarding against, detecting, and reporting malicious software, including:
   a. How to discover malicious software;
   b. How to report malicious software;
   c. How to scan for malicious software that may be contained in email attachments; and/or
   d. How to use anti-virus software.
5. Workforce Members must immediately report suspected or confirmed malicious software to the Privacy & Security Officer or IT Officer.

Responsibility: Privacy & Security Officer; IT Officer;

Definitions: Workforce Member; ePHI; ePHI System;

Regulatory Reference:

- 45 C.F.R. §164.308(a)(5)(ii)(B), Protection from Malicious Software [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date

1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 25
Title: Log-in Monitoring	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: "Implement procedures for monitoring log-in attempts and reporting discrepancies." 45 CFR § 164.308(a)(5)(ii)(C).

Purpose Statement: To regularly track the identification and authentication of those accessing its ePHI Systems, PeriGen will monitor log-in attempts to its ePHI Systems. Such monitoring will ensure that appropriate measures are implemented to verify access to all of PeriGen's ePHI Systems.

Policy/Procedure:

1. The log-in process for each ePHI System will use at least one of the following:
   a. Limitations on the number of unsuccessful log-in attempts;
   b. Software to record failed log-in attempts to the ePHI System; and/or
   c. Time-out periods (10 minutes increasing with every subsequent failure) after a three-failed log-in attempts that may occur during a particular time.
2. The Privacy & Security Officer will determine the standard for the number of log-in attempts allowed for each ePHI System before such failure triggers a timeout period and is logged.
3. If a Workforce Member is accidentally locked out of an ePHI System, he or she should immediately report the situation to his or her supervisor IT Help Desk Vendor. The IT Help Desk Vendor will unlock the Workforce Member's credentials and re-issue the Workforce Member a new temporary password. The Workforce Member will then re-set his or her own individual password.
4. PeriGen will monitor the log-ins of Workforce Members into ePHI Systems in accordance with the Audit Controls Policy.

Responsibility: Privacy & Security Officer,

Definitions: Workforce Member; ePHI; ePHI System; User Regulatory Category: Administrative Safeguards

Regulatory Reference:

- 45 C.F.R. §164.308(a)(5)(ii)(C), Log-In Monitoring [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 26
Title: Password Management	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: "Implement procedures for creating, changing, and safeguarding passwords." 45 C.F.R. §164.308(a)(5)(ii)(D).

Purpose Statement: To prevent unauthorized access to and use of ePHI contained within the ePHI Systems that PeriGen owns or controls, PeriGen requires Workforce Members to take appropriate measures to select and secure passwords that allow such access to ePHI Systems. For ePHI Systems that are not owned or controlled by PeriGen, the Privacy & Security Officer will ensure that its Workforce Members will adhere to the password requirements of each applicable ePHI System.

Policy/Procedure:

1. For ePHI Systems that PeriGen owns or controls:
   a. Passwords must be re-set at least twice a year: January 1st and July 4th.
   b. To maintain accountability, passwords must be individualized and kept confidential by each Workforce Member.
   c. Workforce Members must create and change their own passwords.
   d. Passwords may cycle every 3rd reset.
   e. Passwords cannot be displayed in clear text when inputting them into ePHI Systems.
   f. Passwords must be at least 7 characters in length, including at least one numeric character and one symbol.
   g. Passwords must be committed to memory and not written down
   h. Users may not use Administrator accounts for daily work or tasks that are not Administrative in nature

Responsibility: Privacy & Security Officer;

Definitions: User; Workforce Member; ePHI; ePHI System

Regulatory Reference:

- 45 C.F.R. §164.308(a)(5)(ii)(D), Password Management [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 27
Title: Security Incident Procedures	**Revision 1.0**	**Effective Date**

HIPAA Security Rule Language: "Implement policies and procedures to address security incidents." 45 CFR §164.308(a)(6)(i).

"Identify and respond to suspected or known security incidents; mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity…and document security incidents and their outcomes." 45 CFR §164.308(a)(6)(ii).

Purpose Statement: Despite taking all reasonable and appropriate steps to protect the confidentiality, integrity and availability of ePHI, PeriGen may experience Security Incidents. PeriGen will promptly identify, report, track, and respond to Security Incidents. Awareness of, response to, and creation of reports about Security Incidents are integral parts of PeriGen's efforts to comply with the HIPAA Security Regulations.

Policy/Procedure:

SECURITY INCIDENTS

1. A "Security Incident" is defined as the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations in an ePHI System.
2. The following incidents are examples of potential Security Incidents. This list is not exclusive. The Privacy & Security Officer will determine when a Security Incident has occurred.
    a. Stolen or otherwise inappropriately obtained passwords that are used to access ePHI or PeriGen's ePHI Systems;
    b. Corrupted backup tapes that do not allow restoration of ePHI;
    c. Virus attacks that interfere with the operations of PeriGen's ePHI Systems;
    d. Physical break-ins to PeriGen's facilities that may lead to the theft of electronic media containing ePHI;
    e. PeriGen's failure to terminate the account of a former Workforce Member that is then used by an unauthorized individual to access ePHI Systems; and/or
    f. Allowing electronic media containing ePHI, such as a computer hard drive or laptop, to be accessed by a Workforce Member who is not authorized to access such ePHI prior to removing the ePHI stored on the media.

REPORTING SECURITY INCIDENTS

1. Any Workforce Member, including PeriGen management must report any potential Security Incident that he or she discovers, or any other potential threat to the confidentiality, integrity, or availability of ePHI, to the Privacy & Security Officer immediately upon discovery of the potential Security Incident or threat.
2. The Workforce Member may provide notice of the occurrence of a potential Security Incident in any format, including in writing, electronically, or orally.

3. The Privacy & Security Officer will document the report of a potential Security Incident or threat from the Workforce Member along with the date and time that he or she was notified of such event.
4. PeriGen will not take any retaliatory measures against a Workforce Member who reports a potential Security Incident or threat. If the Security Incident was created by the neglect, or deliberate action, of a Workforce Member, then PeriGen may impose sanctions as set forth in other Policies.
5. No Workforce Member will prohibit or otherwise attempt to hinder or prevent another Workforce Member from reporting a potential Security Incident or threat.

RESPONSE TO SECURITY INCIDENTS

1. Upon becoming aware of a potential or suspected Security Incident, the Privacy & Security Officer will immediately notify PeriGen senior management and legal counsel.
2. If the potential Security Incident involves ePHI or ePHI Systems that PeriGen received access to as a Business Associate of a Covered Entity, legal counsel will review the applicable Business Associate Agreement to determine whether and how the potential Security Incident should be reported to the Covered Entity. Legal counsel will also determine whether any additional notifications are required pursuant to applicable breach notification laws.
3. In consultation with legal counsel and PeriGen senior management, the Privacy & Security Officer will promptly conduct an initial review of the facts surrounding the potential Security Incident to determine whether a Security Incident occurred and, if so, the scope, magnitude and severity of the Security Incident; mechanisms for mitigating the harmful effects of the Security Incident; and, ways to remediate the vulnerability that lead to the Security Incident. The Privacy & Security Officer will present his or her initial findings to PeriGen senior management within 24 hours of becoming aware of the potential Security Incident and will update those findings as more information becomes available.
4. If the Privacy & Security Officer determines that no Security Incident has occurred, the Privacy & Security Officer will document this in a report along with all of the information that supports such conclusion and no further investigations or procedures are required.
5. If the Privacy & Security Officer determines that a Security Incident has occurred, he or she will consult outside counsel to review the initial report to PeriGen senior management and develop a risk management plan that sufficiently responds to the Security Incident.
6. The Privacy & Security Officer and outside counsel must analyze the Security Incident and deliver a response and recommendations to PeriGen senior management within a reasonable time after being convened, but no longer than five (5) days after the date that the Privacy & Security Officer learns of the Security Incident. The response and recommendations must address the cause of the Security Incident, mechanisms for mitigating the harmful effects of the Security Incident, and ways to remediate the vulnerability that lead to the Security Incident
7. The Privacy & Security Officer will retain all documentation regarding the Security Incident in accordance with the PeriGen's Retention Policy.

OTHER MEASURES REGARDING SECURITY INCIDENTS

1. PeriGen will provide training and awareness materials to its Workforce Members, as appropriate, regarding the process for promptly identifying, reporting, tracking, and responding to Security Incidents in accordance with this Policy.
2. PeriGen will work with appropriate third-parties to provide on-going support in the event of a cybersecurity incident response.
3. As deemed necessary by the Privacy & Security Officer, PeriGen will impose sanctions, including termination, in accordance with the Workforce Member Discipline Policy against Workforce Members whose actions lead to or cause Security Incidents.

Responsibility: Privacy & Security Officer,

Definitions: Security Incident; Workforce Member; ePHI; ePHI System.

Regulatory Reference:

- ♦ 45 C.F.R. §164.308(a)(6)(i), Security Incident Procedures [Standard; Required]
- ♦ 45 C.F.R. §164.308(a)(6)(ii), Response and Reporting (of Security Incidents) [Implementation Specification; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

PeriGen

Security Incident Procedure Flowchart Modeled After PeriGen's Security Incident Procedures (Procedure No. 27)

Security Incident: the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations in an ePHI System.

Step 1: All Workforce Members must report any potential Security Incident or any other potential threat to the confidentiality, integrity, or availability of ePHI, to the Privacy & Security Officer supervisor immediately upon discovery of the potential Security Incident or threat. This notice can be in any format.

Step 2: The Privacy & Security Officer will document the report of a potential Security Incident or threat from the Workforce member along with the date and time that he or she was notified of such event.

Step 3: If the supervisor is notified before the Privacy & Security Officer, the supervisor will notify the Privacy & Security Officer. Once the Privacy & Security Officer is notified, he or she will notify senior management (the Management Committee).

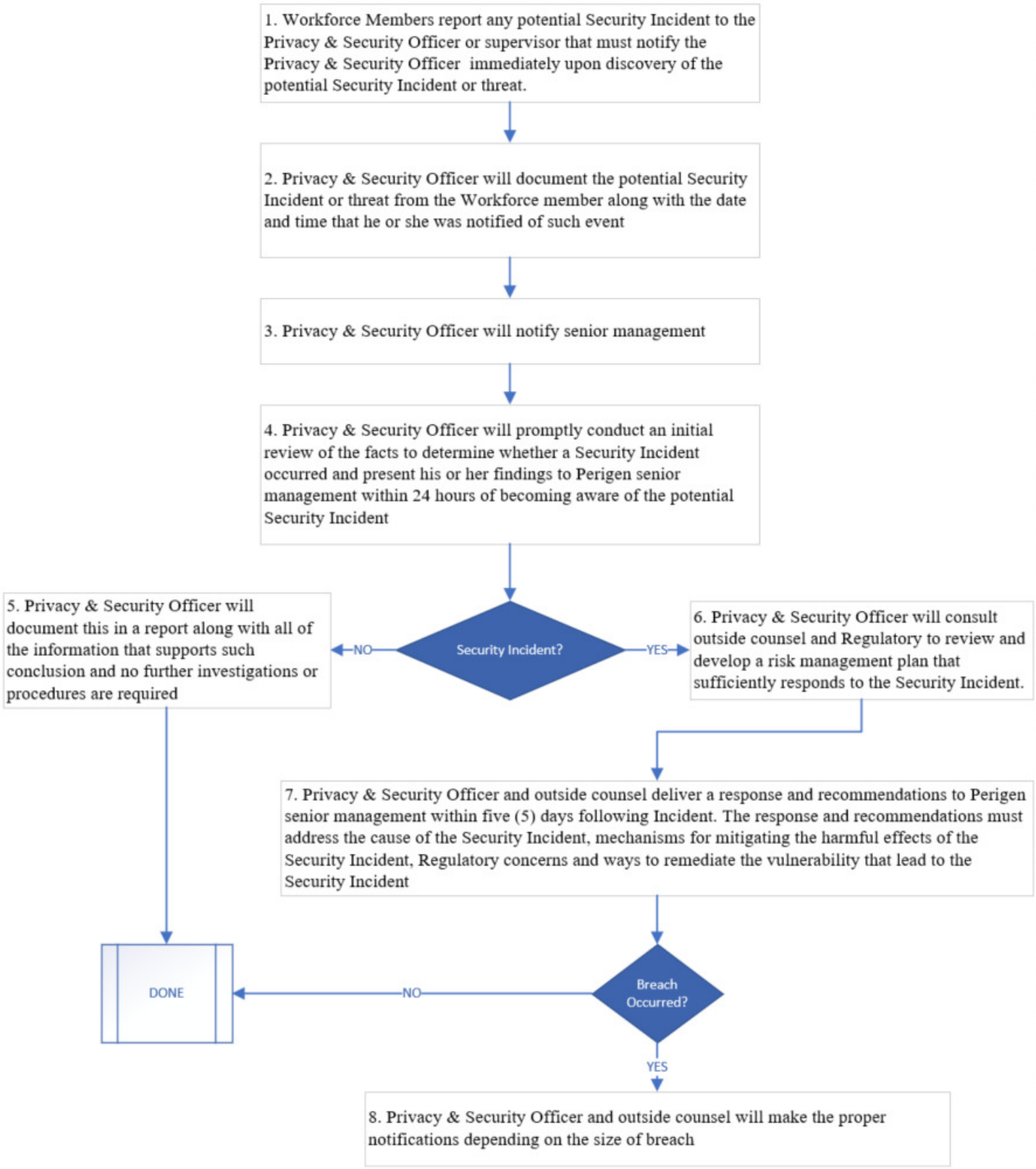
Step 4: In consultation with legal counsel and PeriGen senior management, the Privacy & Security Officer will promptly conduct an initial review of the facts surrounding the potential Security Incident to determine whether a Security Incident occurred and, if so, the scope, magnitude and severity of the Security Incident; mechanisms for mitigating the harmful effects of the Security Incident; and, ways to remediate the vulnerability that lead to the Security Incident. A regulatory assessment will also be conducted for any applicable notification to regulatory bodies. The Privacy & Security Officer will present his or her initial findings to PeriGen senior management within 24 hours of becoming aware of the potential Security Incident and will update those findings as more information becomes available.

Step 5:
If the Privacy & Security Officer determines that no Security Incident has occurred, the Privacy & Security Officer will document this in a report along with all of the information that supports such conclusion and no further investigations or procedures are required.

Step 6:
If the Privacy & Security Officer determines that a Security Incident has occurred, he or she will consult outside counsel to review the Privacy & Security Officer's initial report to PeriGen senior management and develop a risk management plan that sufficiently responds to the Security Incident.

Step 7:
The Privacy & Security Officer and outside counsel must analyze the Security Incident and deliver a response and recommendations to PeriGen senior management within a reasonable time after being convened, but no longer than five (5) days after the date that the Privacy & Security Officer learns of the Security Incident. The response and recommendations must address the cause of the Security Incident, mechanisms for mitigating the harmful effects of the Security Incident, any regulatory considerations and ways to remediate the vulnerability that lead to the Security Incident

Step 8: If the Privacy & Security Officer and outside counsel determine that a breach has occurred, the Privacy & Security Officer and outside counsel will make the proper notifications depending on the size of
the breach. (See http://www.hhs.gov/hipaa/for-professionals/breach-notification/)


1. Workforce Members report any potential Security Incident to the Privacy & Security Officer or supervisor that must notify the Privacy & Security Officer immediately upon discovery of the potential Security Incident or threat.
2. Privacy & Security Officer will document the potential Security Incident or threat from the Workforce member along with the date and time that he or she was notified of such event
3. Privacy & Security Officer will notify senior management
4. Privacy & Security Officer will promptly conduct an initial review of the facts to determine whether a Security Incident occurred and present his or her findings to Perigen senior management within 24 hours of becoming aware of the potential Security Incident
Security Incident?
NO
5. Privacy & Security Officer will document this in a report along with all of the information that supports such conclusion and no further investigations or procedures are required
YES
6. Privacy & Security Officer will consult outside counsel and Regulatory to review and develop a risk management plan that sufficiently responds to the Security Incident.
7. Privacy & Security Officer and outside counsel deliver a response and recommendations to Perigen senior management within five (5) days following Incident. The response and recommendations must address the cause of the Security Incident, mechanisms for mitigating the harmful effects of the Security Incident, Regulatory concerns and ways to remediate the vulnerability that lead to the Security Incident
Breach Occurred?
NO
DONE
YES
8. Privacy & Security Officer and outside counsel will make the proper notifications depending on the size of breach

HIPAA Security Rule Language: "Establish (and implement as needed) policies and procedures for responding to an emergency or other occurrence (for example, fire, vandalism, system failure, and natural disaster) that damages systems that contain electronic PHI." 45 CFR § 164.308(a)(7)(i).

Purpose Statement: PeriGen does not store any PHI on corporate systems. When/if a this changes, PeriGen' s Contingency Plan will establishes procedures to recover its ePHI Systems following a disruption. PeriGen has established the following objectives for this Contingency Plan:

1. Maximize the effectiveness of PeriGen's contingency operations through an established plan that consists of the following phases:
   a. Notification and Activation Phase to detect and assess damage and to activate the plan;
   b. Recovery phase to restore temporary ePHI System operations and to recover damage done to the original ePHI Systems; and
   c. Reconstitution phase to restore each ePHI System's processing capabilities to normal operations.
2. Identify the activities, resources, and procedures needed to carry out each ePHI System's processing requirements during prolonged interruptions to normal operations.
3. Assign responsibilities to designated Workforce Members who will participate in the contingency planning strategies, and provide guidance for recovering each ePHI System during prolonged periods of interruption to normal operations.
4. Ensure coordination with external points of contact and vendors who will participate in the contingency planning strategies.

This Contingency Plan Policy applies to the functions, operations, and resources necessary to restore and resume the operations of PeriGen's ePHI Systems after an emergency or disaster.

Policy/Procedure:

CONTINGENCY PLAN TRIGGERS

This Contingency Plan will be activated when support for the ePHI System will be completely unavailable for more than 5 business hours. This could be due to, but not limited to, network, phone system, computer system, power outages.

NOTIFICATION PROCEDURES

1. PeriGen personnel or a third-party representative who discovers that PeriGen 's facilities, the third party's facilities, or ePHI Systems have been affected by an emergency or disaster, must immediately notify the Privacy & Security Officer, Chief Product Officer or GM, Israel Operations.
2. The Privacy & Security Officer will notify all other personnel within PeriGen who will take part of the contingency and recovery activities.

DAMAGE ASSESSMENT PROCEDURES

The Privacy & Security Officer, or another PeriGen official appointed by the Chief Product Officer, upon his or her initial review of the situation, will assess the following:

a. The cause of the disruption;
b. The potential for additional disruption or damage;
c. The affected physical area and the status of physical infrastructure;
d. The status of the ePHI Systems' server's functionality and inventory, including items that may need to be replaced; and
e. The estimated time to repair services to normal operations.

ACTIVATION OF CONTINGENCY PLAN

The Privacy & Security Officer and other PeriGen official, will determine what contingency operations and recovery activities are necessary to repair and sustain operations of any or all ePHI Systems based on the damage assessment.

RECOVERY OPERATIONS

PeriGen will restore support for its ePHI Systems and recover ePHI in accordance with the following Policies and Procedures:

a. Data Backup Plan and Disaster Recovery Plan Policy; and
b. Emergency Mode Operations Plan.

OTHER CONTINGENCY PLAN PROCEDURES

1. PeriGen will perform a criticality analysis of each ePHI System to determine its importance to PeriGen's operations during or after a disaster.
2. PeriGen will provide periodic training materials regarding its disaster and emergency response procedures to Workforce Members and Users, as appropriate.
3. PeriGen will periodically test its Contingency Plan to ensure that critical business processes can continue in a satisfactory manner. If necessary, PeriGen may revise the Contingency Plan, and the occurrence of any of the following events may result in a revision of the Contingency Plan:
    a. Disaster recovery role and responsibility changes, including changes to contact information;
    b. Changes to PeriGen's physical or technical infrastructure or operating systems;
    c. Changes in threats to ePHI Systems; or
    d. Results of testing that indicate that the plan needs to be modified to ensure that it is sufficient, accurate, and up-to-date.

Responsibility: Privacy & Security Officer,

Definitions: Contingency Event; ePHI; ePHI System; Workforce Member;

Regulatory Category: Administrative Safeguards

Regulatory Reference:

- 45 C.F.R. §164.308(a)(7)(i), Contingency Plan [Standard; Required]

Related Policies: Security Risk Management Policy; Data Backup Plan Policy; Disaster Recovery Plan Policy; Emergency Mode Operations Plan Policy; Testing and Revision of Procedures of Contingency Plan Policy; Criticality Analysis Policy.

Reviewed By: Bruno Bendavid

Approved By: Brian Bishop

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 29
Title: Data Backup Plan and Disaster Recovery Plan	**Revision:**	**Effective**

HIPAA Security Rule Language: "Establish and implement procedures to create and maintain retrievable exact copies of electronic PHI.

Establish (and implement as needed) procedures to restore any loss of data.

Implement procedures for periodic testing and revision of contingency plans." 45 CFR § 164.308(a)(7)(ii)(A)-(B);(D).
Create a retrievable, exact copy of electronic PHI when needed, before movement of equipment." 45 CFR § 164.310(d)(2)(iv).

Purpose Statement: If and when ePHI is maintained by PeriGen, PeriGen stores the data on a secure server. PeriGen has plans in place to create, maintain, and recover exact copies of all ePHI that is contained in any ePHI System. The ability to recover exact copies of all ePHI will enable PeriGen to restore or recover any loss of ePHI and to restore its ePHI System(s) after damage caused by an emergency or disaster, such as fire, vandalism, terrorism, system failure, or natural disaster.

Policy/Procedure:

1. PeriGen's secure server is housed at PeriGen corporate HQ in Cary, NC. The server room has its own thermostat that will send out alerts to at least 4 individuals in the office, including the Privacy & Security Officer, Chief Product Officer, IT Help-Desk, local IT owner.
2. PeriGen's physical server's backups run Monday-Friday between 7:00 A.M. and 6:00 P.M. every 60 minutes and 3 times a week for Saturdays and Sundays at the following times: 12:00 A.M., 8:00 A.M., and 4:00 P.M.
3. PeriGen's backup server is on cloud; backups on the cloud server run Monday to Friday at 6:00 P.M.
4. PeriGen will retain copies of all ePHI contained in its ePHI Systems for a period of six (6) years from the date that such ePHI is entered into such systems.
3. PeriGen will periodically test its Data Backup Plan to ensure that critical business processes can continue in a satisfactory manner during a disaster. If necessary, PeriGen may revise the Data Backup Plan, and the occurrence of any of the following events may result in a revision of the Data Backup Plan:
    a. Changes to PeriGen's physical or technical infrastructure or operating systems;
    b. Changes in threats to its ePHI Systems or other applications that are supported by or interact with its ePHI Systems; or
    c. Results of testing that indicate that the plan needs to be modified to ensure that it is sufficient, accurate, and up-to-date.
4. In the event of an emergency or disaster, such as a fire, vandalism, terrorism, system failure, or natural disaster, PeriGen will use data retrieved from its backup

repository to restore its ePHI Systems' functionality in accordance with the Contingency Plan Policy #28 and the Disaster Recovery Plan (attached).

Responsibility: Privacy & Security Officer;

Definitions: ePHI; ePHI System

Regulatory Category: Administrative Safeguards

Regulatory Type:

Regulatory Reference:

- 45 C.F.R. §164.308(a)(7)(ii)(A), Data Backup Plan [Implementation Specification; Required]
- 45 C.F.R. §164.310(d)(2)(iv), Data backup and storage [Implementation Specification; Addressable]
- 45 C.F.R. §164.308(a)(7)(ii)(B), Disaster Recovery Plan [Implementation Specification; Required]
- 45 C.F.R. §164.308(a)(7)(ii)(D), Testing and Revision Procedures [Implementation Specification; Addressable]

Related Policies: Security Management, Process, Risk Analysis and Risk Management Plans Policy, Data Backup Plan Policy; Emergency Mode Operations Plan Policy; Testing and Revision of Procedures of Contingency Plan Policy; Criticality Analysis Policy.

Reviewed By: Bruno Bendavid

Approved By: Brian Bishop

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

EXAMPLE –
DISASTER RECOVERY PLAN

OVERVIEW

Every Workforce Member in the PeriGen - staff, and visitors - must take appropriate and deliberate action when an emergency strikes a building, a portion of the office, or the entire office. Decisive leadership is essential. Follow these important steps when there is an emergency:

- ✓ Confirm and evaluate conditions
- ✓ Report the incident immediately
- ✓ Follow instructions from the C-Suite or the Privacy & Security Officer precisely
- ✓ Depending on the nature and severity of the event, notify
  - ♦ All area staff and occupants
- ✓ Issue clear and consistent emergency notifications. Use all available communications tools
  - ♦ If there is no power or telephone systems are not functioning, emergency communications will be made using cellular phones, messengers, and email.

When an emergency strikes the office after normal business hours, or on weekends or holidays - or, if you are off-site during a major emergency, obtain instructions from the C-Suite or the Privacy & Security Officer and monitor media reports.

If you are recalled to the office, be certain that your safety is assured and that your route to the office is safe and functional.

US-based Office

The following person is our primary crisis manager and will serve as the company internal spokesperson in an emergency:

Primary Emergency Contact: Brian Bishop
Telephone Number: 919-760-9766
Alternative Number: 984-208-4160
E-mail: brian.bishop@PeriGen.com

If the person is unable to manage the crisis, the person below at our location will succeed in management:

Secondary Emergency Contact: Drew Messick
Telephone Number: 919-244-9903
Alternative Number: 984-208-4193
Email: Andrew.messick@PeriGen.com

If the person is unable to manage the crisis, the person below at our location will succeed in management:

Third Emergency Contact: Matt Sappern
Telephone Number: 609-917-4695
Alternative Number:
Email: matthew.sappern@PeriGen.com

Canadian-based Office

The following person is our primary crisis manager and will serve as the company internal spokesperson in an emergency:

Primary Emergency Contact: Bruno Bendavid
Telephone Number: 514-978-0611
Alternative Number: 514-369-0730
E-mail: Bruno.bendavid@PeriGen.com

If the person is unable to manage the crisis, the person below at our location will succeed in management:

Secondary Emergency Contact: Emily Hamilton
Telephone Number: 514-488-3461 X 226
Alternative Number: 514-246-8571
Email: Emily.hamilton@PeriGen.com

If the person is unable to manage the crisis, the person below at our location will succeed in management:

Third Emergency Contact: Matt Sappern
Telephone Number: 609-917-4695
Alternative Number:
Email: matthew.sappern@PeriGen.com

Israeli-based Office

The following person is our primary crisis manager and will serve as the company internal spokesperson in an emergency:

Primary Emergency Contact: Natan Blanks
Telephone Number: 972-3-9059900 x 919
Alternative Number: 972-54-4699679
E-mail: natan.blanks@PeriGen.com

If the person is unable to manage the crisis, the person below at our location will succeed in management:

Secondary Emergency Contact: Simi Nitzan Tzidkiyahu
Telephone Number: 972-3-9059900 x 904
Alternative Number: 054-3005176

Email: simi.nitzan@PeriGen.com

If the person is unable to manage the crisis, the person below at our location will succeed in management:

Third Emergency Contact: Matt Sappern
Telephone Number: 609-917-4695
Alternative Number:
Email: matthew.sappern@PeriGen.com

Please contact the IT vendor listed below for any emergencies that involve electronic equipment handled by DSI:

IT Vendor: DSI
Telephone Number: 609-642-9748

Privacy & Security Officer:
Telephone Number:
Email: Bruno.Bendavid@PeriGen.com

RECOVERY PLAN ELEMENTS

1. Recovery Plan for Disasters

The cycle from the occurrence of a disaster to the full restoration of normal processing has four (4) phases:

1) Initial response;
2) Preparation for temporary backup site operations;
3) Backup site fully operational, and
4) Restoration and return to permanent facility.

A. Detection and Reaction

As soon as an emergency happens, the on-site personnel must contact the appropriate emergency authorities and then take the necessary steps to minimize property damage and injury to people in the vicinity. Following these procedures, they will then contact the CEO, CPO, GM Israeli Operations and/or the Privacy & Security Officer to make an on-site evaluation of the disaster.

B. Identifying the problem – Notifying the authorities

Emergency services

Telephone the following numbers to reach local authorities for emergencies such as fire, explosion, earthquake, tornado, etc.

Functions	Contact Numbers Office
Paramedics	
Fire Department	
Ambulance	
Police/Fire/Ambulance	**911**

C. Emergency Response Actions

Following the procedures below will help reduce the facility's exposure to additional losses because of actions not taken by on-site personnel. These actions are targeted at emergencies concerning any accident, injury, mother-nature disasters, fire, and/or water damage:

i. Accident

(1) Call **911** for emergencies.
(2) Administer first aid if you are trained to do so.
(3) Do not attempt to move a seriously injured person.
(4) Ensure the Chief Product Officer is notified.

ii. Earthquake/Tornado

Earthquake

(1) Take cover immediately, direct others around you
(2) Seek sturdy shelter under
    (a) A desk, table, or chair
    (b) Between seating rows in lecture halls
    (c) Against a corridor wall (cover head and neck)
    (d) Outdoors--in open area, away from buildings
(3) Be alert for aftershocks, avoid potential falling hazards

(4) **Tornado**

    (a) Take shelter in a basement, restroom, or the lowest level available
    (b) Put as much space between you and the outside walls
    (c) Stay far away from windows
    (d) Seek sturdy shelter
    (e) Notify the Chief Product Officer to ensure safety of all Workforce Members.

iii. Power Outage

(1) Report the outage to CPO, CFO and/or Privacy & Security Officer.
(2) Notify Director, Technical Client Services and Remote Operations to transfer scheduling calls to the answering services.
(3) Assess the extent of the outage in your area (if necessary):
    (a) Obtain information about a prolonged outage
    (b) Unplug all computers, non-essential electrical equipment and appliances
    (c) Open windows for additional light and ventilation
    (d) If you are asked to evacuate, secure any hazardous materials and leave the building Release of personnel after an extended outage is determined by the C-Suite.

iv. Fire Alarm Procedures

The fire alarm system can detect fires within the first few seconds. It notifies the local fire department through 24-hour, central-station monitoring. If the fire alarm system has not been activated, but fire or smoke is detected, do the following:

(1) Quickly assess the surrounding environment to determine the source of the problem.

(2) If the situation looks manageable, use one of the hand held fire extinguishers to attempt to extinguish the fire. NOTE: Fire extinguisher is located in the break room and rear exit of the office; instructions on how to operate the fire extinguisher will be displayed on it. Immediately notify the Safety Coordinator a fire event has occurred. After the use of the fire extinguished, if fire has not extinguished, go to the Emergency Assembly Point (EAP).

[ENTER PHYSICAL NAME AND LOCATION FOR EAP HERE]

<u>If unable to extinguish the fire and there is time to do the following SAFELY:</u>

(a) Pull the fire alarm.
(b) Call the Fire Rescue Department **911**
(c) Power down all computer equipment.
(d) Evacuate downstairs, go upstairs or to roof as last resort only
(e) Go to the **Emergency Assembly Point (EAP)**

[ENTER PHYSICAL NAME AND LOCATION FOR EAP HERE]

(3) If the building's fire alarm goes off, immediately notify the Safety Coordinator and evacuate to the EAP.

(4) Notify the **IT Management and the Privacy & Security Officer from the Emergency Contact List.**

v. Flood and Water Damage.

Water damage can be caused from a discharge or leak in the sprinkler system, broken pipes, bathroom facilities, or the flow of water into any room from another area of the building because of fire, etc. The following steps must be followed if there is a water problem:

(1) If the Water Damage Exposure Has Affected the Computer Hardware:

(a) Power down the computer equipment.

(b) Notify the CPO, CFO and/or Privacy & Security Officer, who will then notify IT Management.

(c) The Privacy & Security Officer or his/her designee will contact DSI and other hardware Providers as required to have the equipment checked for damage before the equipment is powered up.

(d) The Privacy & Security Officer or his/her designee will advise the DSI staff so they can verify that all files are properly restored.

(e) The Privacy & Security Officer or his/her designee will notify the staff members of the expected time the system will be running.

vi. Evacuation of the Facility.

Workforce Members will be evacuated from the facility if the building is unsafe. Workforce Members will be constantly trained in emergency procedures and will know evacuation routes from various parts of the building. Drills are conducted periodically to refresh the memory of long-term Workforce Members and give instructions to new Workforce Members. The drills

inform them as to which people are responsible for directing the evacuation and checking that all areas have been properly cleared.

vii. Advising the Executive Management of the Situation.

As soon as possible after a disaster, notify the Executive Management Team, or the C-Suite. It is the responsibility of the CPO and/or the Privacy & Security Officer to make sure the team is advised of the situation. If the on-site person was unable to contact the Privacy & Security Officer or his/her designee, that person will now be responsible for contacting the Executive Management Team. The team members will be phoned in the following sequence until someone is reached. The person reached will continue to call the remaining team members.

Name	Position	Office Phone	Cell Phone
1st contact	CEO		609-917-4695
2nd contact	CPO	984-208-4160	919-760-9766
3rd contact	CFO	984-208-4193	919-244-9903
4th contact	CCO	TBD	TBD

viii. Creating Workflow Procedures for the Detection and Response

The following section (2) lists the recovery steps in the DR Plan for Phase 1: Detection and Response.

2. Roles and Responsibilities

Heading Name	Executed by	Action Taken
Detection and Reaction	Workforce Member	Call Emergency Services or
		Call CPO or Privacy & Security Officer
Emergency Response Action		Follow Emergency Procedures for fire, electrical failure, or water
		Power down computer equipment and air-conditioning, contact maintenance, minimize water damage by covering equipment
Evacuation	All occupants	Leave building
Advising Emergency	Workforce Member	Call emergency services as required
Executive Management Team	C-Suite	Assess damage, reporting, evaluation, etc.

3. Documenting Emergency Outcomes

Once the safety and status of all Workforce Members has been assured, and emergency conditions have abated, it will be important to begin a timely and comprehensive assessment of the emergency's physical and operational effects.

The purpose of the checklist is to provide a guide in the review and assessment of damage following a disaster to PeriGen's office, the network and/or the server room.

1. Is the area safe for employees or vendors to work in?

2. Can the equipment under examination function, and if so, at what percent of normal capacity?

3. What must be done to recover damaged equipment?

4. How long will it take to repair or replace the damaged equipment?

Level I Minimal damage to facility and/or equipment. Estimated time to complete repairs is less than 4 hours.

Level II Moderate damage to facility and/or equipment. Estimated time to complete repairs is between 4 hours and two business days.

Level III Extensive damage to facility and/or equipment. Estimate time to complete repairs is greater than two business days.

1. Identify equipment, documentation or spare parts which are immediately salvageable or in need of repair.
2. Verbally notify the C-Suite of survey, assessment of damage, estimated time to recover from damage and potentially salvageable equipment
3. Document findings from the survey and damage assessment.

Initials: _____ Date: _____ Time: _____

	HIPAA Security	Procedure No.: 30
Title: Emergency Mode Operation Plan	Revision:	Effective

HIPAA Security Rule Language: "Establish (and implement as needed) procedures to enable continuation of critical business processes for protection of the security of electronic protected health information while operating in emergency mode.

Implement procedures for periodic testing and revision of contingency plans." 45 CFR § 164.308(a)(7)(ii)(C)-(D).

Purpose Statement: PeriGen will develop and implement an Emergency Mode Operation Plan to enable the continuation of its critical business processes and to protect the security of ePHI while PeriGen operates in emergency mode. PeriGen's Emergency Mode Operation Plan will permit authorized Workforce Members to access and use ePHI available in its ePHI Systems during and immediately following an emergency or disaster. Emergency mode operation procedures detailed in the Emergency Mode Operation Plan must be tested on an annual basis to ensure that critical business processes can continue in a satisfactory manner while PeriGen operates in emergency mode.

Policy/Procedure:

1. PeriGen Emergency Mode Operation Plan will:
    a. Define and categorize reasonably foreseeable emergencies and/or disasters that could have an impact on the confidentiality, integrity, and availability of ePHI contained in and available through its ePHI Systems.
    b. Include a procedure that specifies how its ePHI Systems will react to emergencies and disasters.
    c. Include a procedure that outlines how its ePHI Systems will maintain security processes and controls during and immediately following an emergency or disaster.
    d. Authorize designated Workforce Members to enter PeriGen's offices and facilities and any offsite location where backup media are stored to maintain the security processes and controls of ePHI Systems.
    e. Identify the roles that particular PeriGen Workforce Members will serve while PeriGen is operating in emergency mode.
    f. Identify the roles of designated Workforce Members who will be permitted to administer or modify processes and controls that protect the security of ePHI while PeriGen is operating in emergency mode.
2. PeriGen will make its Emergency Mode Operations Plan easily available to its Workforce Members at all times.
3. PeriGen will annually test its Emergency Mode Operations Plan to ensure that critical business processes can continue in a satisfactory manner. If necessary, PeriGen may revise the Emergency Mode Operations Plan, and the occurrence of

any of the following events may result in a revision of the Emergency Mode Operations Plan:

a. Disaster recovery role and responsibility changes, including changes to contact information.
b. Changes to PeriGen's physical or technical infrastructure or operating systems.
c. Changes in threats to ePHI Systems.
d. Results of testing that indicate that the plan needs to be modified to ensure that it is sufficient, accurate, and up-to-date.

Responsibility: Privacy & Security Officer;

Definitions: ePHI; ePHI System; Workforce Member;

Regulatory Category: Administrative Safeguards

Regulatory Reference:

- 45 C.F.R. §164.308(a)(7)(ii)(C), Emergency Mode Operation Plan [Implementation Specification; Required]
- 45 C.F.R. §164.308(a)(7)(ii)(D), Testing and Revision Procedures [Implementation Specification; Addressable]

Related Policies: Security Management, Process, Risk Analysis and Risk Management Plans Policy; Contingency Plan Policy; Data Backup Plan and Disaster Recovery Plan Policy; Emergency Mode Operations Plan Policy; Testing and Revision of Procedures of Contingency Plan Policy; Criticality Analysis Policy.

Reviewed By:

Approved By:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 31
Title: Applications and Data Criticality Analysis	**Revision:**	**Effective**

HIPAA Security Rule Language: "Assess the relative criticality of specific applications and data in support of other contingency plan components." 45 C.F.R. §164.308(a)(7)(ii)(E).

Purpose Statement: The purpose of the criticality analysis is for PeriGen to document the impact to its services, processes, and operating objectives if a disaster or other emergency causes any or all of PeriGen's ePHI Systems to become unavailable for a documented period of time. The criticality analysis will serve as the basis for the prioritization of each ePHI System and the importance of its functionality to PeriGen's business operations during a disaster.

Policy/Procedure:

1. To prioritize PeriGen's ePHI and other business critical Systems for disaster recovery, the Information Technology Department will develop a matrix, which:
   a. Inventories all systems, including ePHI Systems; and
   b. Determines the necessity of each ePHI System to the operation of PeriGen's critical business functions.
2. The matrix will be used to determine which ePHI Systems are most important to the operation of PeriGen's critical business functions and thereby determine how disaster recovery efforts will be focused during a Contingency Event or other disaster.
3. The matrix may direct:
   a. Which ePHI System(s) will be restored first; and/or
   b. Which ePHI System(s) will receive the first line of assistance during a disaster.
4. PeriGen will conduct a yearly data criticality analysis as part of its risk assessment in accordance with the Security Risk Management Policy.
5. The Privacy and Security Officer will be responsible for documenting all activities relating to the data criticality analysis, and such documentation will be maintained and retained by the Privacy & Security Officer for six years from the date of creation.

Responsibility: Privacy & Security Officer
Definitions: ePHI; ePHI System; Contingency Event
Regulatory Category: Administrative Safeguards
Regulatory Reference:

- ♦ 45 C.F.R. §164.308(a)(7)(ii)(E), Applications and Data Criticality Analysis [Implementation Specification; Addressable]

Related Policies: Security Management Process, Risk Analysis and Risk Management Plan; Contingency Plan Policy

Reviewed By: Bruno Bendavid
Approved By: Brian Bishop

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 32
Title: Evaluation of Security Policies and Procedures	**Revision: 1.0**	**Effective Date:**

HIPAA Security Rule Language: Perform a periodic technical and non-technical evaluation, based initially upon the standards implemented under this rule and subsequently, in response to environmental or operational changes affecting the security of electronic PHI that establishes the extent to which a covered entity's security and procedures meet the requirements of this subpart." 45 C.F.R. §164.308(a)(8).

Purpose Statement: Periodic evaluations of PeriGen's security safeguards, especially in response to environmental or operational changes, are necessary to re-affirm that ePHI continues to be protected in accordance with the HIPAA Security Regulations. This policy reflects PeriGen's commitment to comply with such Regulations.

Policy/Procedure:

1. PeriGen will undertake periodic evaluations of its security safeguards at intervals determined by the Privacy & Security Officer based on the specific triggers and the characteristics of each ePHI System. (at least annually)
2. Changes that may trigger a reevaluation of PeriGen's security safeguards include, but are not limited to:
   a. Known Security Incidents;
   b. Significant new threats or risks to the security of ePHI;
   c. Changes to PeriGen's organizational or technical infrastructure;
   d. Introduction of new ePHI Systems;
   e. Changes to information security requirements or responsibilities; and/or
   f. Availability of new security technologies or recommendations.
3. PeriGen will periodically evaluate its ePHI Security Policies on a annual basis.
4. Each evaluation may include the following activities:
   a. A review of PeriGen's Security Policies and Procedures to evaluate their appropriateness and effectiveness in protecting against any reasonably anticipated threats or hazards to the privacy and security of ePHI.
   b. A gap analysis to compare PeriGen's Security Policies and Procedures against actual practices.
   c. An identification of threats and risks to ePHI and ePHI Systems, in accordance with the Security Risk Management Policy.
   d. An assessment of whether established security controls reasonably and appropriately protect against the risks identified for ePHI and each ePHI System.

5. The evaluation process will be documented, and the evaluation's findings will be reported to the Privacy & Security Officer and PeriGen senior management.
6. Upon review of the evaluation report, the Privacy & Security Officer, if necessary, may initiate the development of a risk management plan, or other measure, to address any deficiencies discovered during the evaluation process.
7. Upon implementation of the risk management plan or upon the completion of the evaluation process, PeriGen will update its Security Policies and Procedures, security controls, and processes if the results of the evaluation show that such updates are needed.

Responsibility: Privacy & Security Officer;

Definitions: ePHI; ePHI System; Security Incidents

Regulatory Reference:

- ♦ 45 C.F.R. §164.308(a)(8), Evaluation [Standard; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

HIPAA Security Rule Language: "Implement policies and procedures to limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properly authorized access is allowed." 45 CFR § 164.310(a)(1).

"Establish (and implement as needed) procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency.

Implement policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft.

Implement procedures to control and validate a person's access to facilities based on their role or function, including visitor control, and control of access to software programs for testing and revision.

Implement policies and procedures to document repairs and modifications to the physical components of a facility which are related to security (for example, hardware, walls, doors and locks." Implement procedures for periodic testing and revision of contingency plans." 45 CFR § 164.310(a)(2)(i)-(iv).

Purpose Statement: PeriGen will limit physical access to its ePHI Systems and to the facility or facilities in which they are located or accessible. Such access will be granted only to those Workforce Members and individuals who have been authorized to access PeriGen's facilities and areas where ePHI Systems are contained or accessible. During a Contingency Event, PeriGen will allow physical access to its facilities that contain ePHI Systems only to those authorized pursuant to its Contingency Plan. PeriGen will implement facility security controls to protect its facilities from unauthorized physical access, tampering, and theft. PeriGen will maintain records documenting any repairs or modifications that impact the physical security of its facilities or equipment.

Policy/Procedure:

FACILITY ACCESS

1. PeriGen operates three locations.
2. Access into the PeriGen facility is limited to PeriGen Workforce Members.
3. Visitors and vendors may be granted physical access to the facility in accordance with the following procedures:
   a. PeriGen's main door will remain locked between 4:30pm and 8:00am.
   b. When the door is locked, PeriGen visitors will appear outside of the locked door and will ring the doorbell, at which time, a PeriGen staff member will greet the visitor.

c. The staff member can then allow the visitor access to the main building. Visitors and vendors must be properly identified and state the reason(s) why they need access to the facility.
d. Each visitor or vendor must sign the sign-in sheet and enter the following information:
    i. time of entry
    ii. time of exit
    iii. Purpose of access
e. The Workforce Member will escort visitors and vendors to their destination within the facility.

FACILITY SECURITY CONTROLS

1. Workforce Member's access badge to the PeriGen office will be deactivated when a Workforce Member departs.
2. PeriGen will supervise all visitors and vendors while they are physically present in its facilities.
3. PeriGen may install the following security controls to protect its facilities from unauthorized access, tampering and theft based on its risk analysis:
    a. Warning Signs
    b. Security System
    c. Alarms

FACILITY REPAIRS AND MODIFICATIONS

1. The appropriate building maintenance personnel will notify the Office Manager when a repair or modification to one of PeriGen's facilities is required.
2. No repair or modification that may impact the physical security of PeriGen's facilities may be commenced until proper authorization is granted by the Chief Product Officer or other appropriate member of PeriGen's senior management.
3. Examples of repairs or modifications include, but are not limited to:
    a. Re-keying door locks
    b. Changing security codes for alarms and doors
    c. Repair or replacement of the access card reader or fob
    d. Activation or deactivation of access cards or fob
4. PeriGen will document repairs and modifications made to its facilities that are related to the physical security of the facility or equipment. The Office Manager will maintain documentation on each repair or modification, which includes the following information:
    a. Name of the Workforce Member who authorized the repair or modification;
    b. Date and time of the repair or modification;
    c. Description of the condition of the physical component prior to the repair;
    d. Reasons for the repair or modification, including any damage from a Security Incident;
    e. Person(s) performing the repair or modification; and
    f. The outcome of the repair or modification.

Responsibility: Office Manager,

Definitions: ePHI; ePHI System; Vendor; Workforce Member

Regulatory Reference:

- 45 C.F.R. §164.310(a)(1), Facility Access Controls [Standard; Required]
- 45 C.F.R. §164.310(a)(2)(i), Contingency Operations [Implementation Specification; Addressable]
- 45 C.F.R. §164.310(a)(2)(ii), Facility Security Plan [Implementation Specification; Addressable]
- 45 C.F.R. §164.310(a)(2)(iii), Access Control and Validation Procedures [Implementation Specification; Addressable]
- 45 C.F.R. §164.310(a)(2)(iv), Maintenance Records [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

HIPAA Security Rule Language: "Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed, and the physical attributes of the surroundings of a specific workstation or class of workstation that can access electronic PHI." 45 CFR § 164.310(b).
"Implement physical safeguards for all workstations that access electronic protected health information, to restrict access to authorized users." 45 CFR § 164.310(c).

Purpose Statement: Workstations (laptops and desktops) will be used in a manner that is consistent with PeriGen's business purposes. PeriGen requires the implementation of reasonable physical safeguards to protect all workstations and other electronic devices that access, store or transmit ePHI from theft or unauthorized use. PeriGen will periodically review (quarterly), and may modify as appropriate, the permitted and prohibited uses of Workstations and the security controls implemented to protect Workstations in accordance with the Security Risk Management Policy. PeriGen will periodically distribute training and education materials to Workforce Members regarding the use and security of Workstations.

Policy/Procedure:

WORKSTATION USE

1. PeriGen informs Workforce Members of permissible and prohibited uses of Workstations, including personal use.
2. The same permissible and prohibited uses of Workstations apply to all Workstations regardless of their location.

WORKSTATION SECURITY

1. PeriGen will require Workforce Members to have unique user identifiers and passwords to gain access to their Workstations.
2. Workforce Members must activate workstation locking software upon leaving a Workstation for more than ten (10) minutes.
3. Workforce Members must log off from their Workstations when their work-day shift is complete.
4. PeriGen will ensure that anti-virus software, which is configured to receive anti-virus updates, is installed on all Workstations that Workforce Members and use in accordance with the Malicious Software Policy.
5. These same Workstation security procedures apply to all Workstations regardless of the Workstation's location.

Responsibility: Privacy & Security Officer;
Definitions: ePHI; ePHI System; Workforce Member; Workstation
Regulatory Reference:
45 C.F.R. §164.310(b), Workstation Use [Standard; Required]
45 C.F.R. §164.310(c), Workstation Security [Standard; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 35
Title: Device and Media Controls	**Revision: 1.0**	**Effective Date:**

HIPAA Security Rule Language: Implement policies and procedures that govern the receipt and removal of hardware and electronic media that contain electronic PHI into and out of a facility, and the movement of these items within the facility. 45 CFR § 164.310(d)(1).

"Implement policies and procedures to address the final disposition of electronic protected health information and/or the hardware or electronic media on which it is stored.

Implement procedures for removal of electronic protected health information from electronic media before the media are made available for re-use.

Maintain a record of the movements of hardware and electronic media and any person responsible therefore." 45 CFR § 164.310(d)(2)(i)-(iii).

Purpose Statement: PeriGen will take reasonable and appropriate steps to control its hardware and electronic media that contain ePHI throughout the media's entire lifecycle, from initial receipt to final removal. Such control includes reasonably and appropriately protecting, accounting for, storing, backing up, and disposing of its hardware and electronic media in accordance with specific control procedures and tracking all incoming hardware and electronic media and transfers of hardware and electronic media as they are moved into and out of PeriGen's direct control and premises.

Policy/Procedure:

INVENTORY AND MOVEMENT OF HARDWARE AND ELECTRONIC MEDIA

1. PeriGen will take an inventory of hardware and electronic media that contain ePHI every six months. Workforce Members will be advised that they should not save any ePHI to electronic media unless required to do to perform their job functions.
2. If a Workforce Member is required to save ePHI to electronic media to perform his or her job functions, it may only be saved to hard drives and approved USB drives. No other media may be used to store ePHI. Only PeriGen-owned USB/flash drives are permitted for the e-PHI to be stored. All PeriGen-owned USB/flash drives used in the process will be logged and must be signed out by the Director of Quality and Regulatory or his/her designee. Any e-PHI on the USB/flash drive that was used to perform the task will be disposed upon returning the USB/flash drive.
3. Prior to moving hardware or other electronic media that contain ePHI outside of PeriGen's facilities and out of the direct control of PeriGen, the Privacy & Security Officer must be notified of and grant authorization for such movement.
4. PeriGen will maintain documented records regarding the movement of hardware or other electronic media containing ePHI outside of PeriGen's facilities and outside of PeriGen's direct control. Documentation regarding the movement of hardware or electronic media will be required only for desktop computers, laptops, and other

media storage devices that can be tracked. The following information must be documented in each record regarding the movement of hardware or electronic media:

a. Date of movement
b. Method of movement
c. Description of the moved medium
d. Dates indicating the time period that the moved medium was used at PeriGen
e. Dated signatures of the Privacy & Security Officer and all Workforce Members supervising the movement.

DISPOSAL OF EPHI, HARDWARE AND ELECTRONIC MEDIA

1. Hardware and Electronic Media
   a. PeriGen will take all reasonable and appropriate steps to remove ePHI from hardware and electronic media prior to the final disposal of the hardware or electronic media.
   b. The Privacy & Security Officer will determine which sanitization method is appropriate for the removal of ePHI from hardware and/or electronic media.
   c. The following sanitization methods may be used to remove ePHI from hardware and/or electronic media:
      i. Clearing
         1. Overwrites storage space on the hardware or electronic media with non-sensitive data.
         2. The hardware and/or electronic media type and size may influence whether overwriting is a suitable sanitization method.
         3. PeriGen will consult the National Institute of Standards and Technology (NIST) *Guidelines for Media Sanitization,* Publication 800-88 regarding its recommendations for clearing different media types.
         4. PeriGen will use an appropriate tool or method to clear ePHI from any hard drives or USB drives that may contain ePHI.
      ii. Purging
         1. Degaussing is an acceptable method of purging.
         2. Degaussing exposes the magnetic media to a strong magnetic field in order to disrupt the recorded magnetic domains.
         3. Degaussing cannot be used to purge nonmagnetic media, such as optical media or compact discs (CDs).
         4. PeriGen will consult the National Institute of Standards and Technology (NIST) *Guidelines for Media Sanitization,* Publication 800-88 regarding its recommendations for clearing different media types.
   d. If hardware and/or electronic media cannot be cleared or purged, the only method of disposal is to physically destroy the hardware and/or electronic

media. Acceptable methods of destroying hardware and/or electronic media include:

i. Disintegration ii. Incineration iii. Pulverization iv. Melting

v. Shredding

e. PeriGen will document the disposal of all hardware and electronic media disposal and the steps taken to remove ePHI prior to the disposal of such hardware and electronic media.

f. The Privacy & Security Officer or his or her designee will inspect all hardware and electronic media to ensure that all ePHI has been removed from the hardware or electronic media prior to disposal.

MEDIA RE-USE

1. For the internal re-use of hardware and/or electronic media, such as the redeployment of a computer to another PeriGen business unit or Workforce Member, PeriGen will reformat all files on the hardware and/or electronic media so that such files are not accessible. Clearing of files and documents from previous equipment will be logged before redeployment of the computer to another PeriGen business unit or Workforce Member within 30 days. The process for redeployment of a computer previously used by a Workforce Member who is no longer employed at PeriGen is as follows:
   a. IT vendor will access all applications the previous Workforce Member had and cut off all access;
   b. IT vendor will capture all files and documents the previous Workforce Member had and will save on a drive on the server;
   c. IT vendor will wipe the computer clean;
   d. C-Suite will dictate the access to the drive on the server to access previous Workforce Member's files.
2. For external re-use of hardware and/or electronic media (e.g. Donation or return of leased hardware), PeriGen will completely and permanently remove ePHI from the hardware and/or electronic media in accordance with the Disposal procedures of this Policy.

Responsibility: Privacy & Security Officer; Director of Quality and Regulatory

Definitions: ePHI

Regulatory Reference:

- 45 C.F.R. §164.310(d)(1), Device and Media Controls [Standard; Required]
- 45 C.F.R. §164.310(d)(2)(i), Disposal [Implementation Specification; Required]
- 45 C.F.R. §164.310(d)(2)(ii), Media Re-Use [Implementation Specification; Required]

- 45 C.F.R. §164.310(d)(2)(iii), Maintenance of Records regarding Movements of Hardware and Media [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 36
Title: Technical Access Controls	Revision: 1.0	Effective Date:

HIPAA Security Rule Language: Implement technical policies and procedures for electronic information systems that maintain electronic PHI to allow access only to those persons or software programs that have been granted access rights as specified in 45 C.F.R. §164.308(a)(4) [“Implement policies and procedures for authorizing access to electronic PHI that are consistent with the applicable requirements of subpart E of this part.”]. 45 CFR §164.312(a)(1).

“Assign a unique name and/or number for identifying and tracking user identity.

Establish (and implement as needed) procedures for obtaining necessary electronic PHI during an emergency.

Implement electronic procedures that terminate an electronic session after a predetermined period of inactivity.

Implement a mechanism to encrypt and decrypt electronic PHI.” 45 CFR §164.312(a)(2)(i)-(iv).

Purpose Statement: To protect the confidentiality, integrity, and availability of ePHI, PeriGen has taken reasonable and appropriate steps to ensure that its ePHI Systems have technical safeguards to control and restrict access to its ePHI Systems to persons who are authorized to have such access in accordance with the Information Access Management Policy.

Policy/Procedure:

PeriGen will implement appropriate technical security controls and methods that permit only authorized persons to access its ePHI Systems. Such controls and methods include, but are not limited to, the following:

a. Issuance of unique user identifications (user IDs) for each Workforce Member to be used in conjunction passwords as part of PeriGen’s authentication measures.
b. Activation of password protected screensaver on Workstations after a designated period of inactivity (15 minutes).
c. Automatic lock after a designated period of inactivity (15 minutes).
d. Requiring Workforce Members to logoff or lock Workstations upon leaving their work areas.
e. Encryption (128-bit or greater), when appropriate and technically feasible, of ePHI through its ePHI Systems.

UNIQUE USER IDs

1. PeriGen will control access to its ePHI Systems by assigning each Workforce Member who is granted access to an ePHI System a unique user ID that: a. Identifies the individual Workforce Member; and/or
   b. Permits activities performed in ePHI Systems to be traced to the individual Workforce Member.
2. The Workforce Member's ID itself should not indicate the individual's access privileges but should be tied to the Workforce Member's role.

WORKSTATION SCREENSAVERS FOR PeriGen WORKFORCE MEMBERS

1. All PeriGen Workstations will be equipped with screensavers that will automatically activate after 5 minutes of inactivity.
2. Workforce Members can only deactivate the Workstation screensaver by entering his or her confidential password when prompted.

ENCRYPTION AND DECRYPTION

1. PeriGen will – when feasible – implement secure protocols, which encrypt data while such data is being electronically transmitted. In addition, these secure protocols allow decrypted data to be presented to the Workforce Member upon its arrival to his or her Workstation.
2. Unauthorized access to ePHI transmitted through its ePHI Systems is prevented through the use of the administrative, technical and physical safeguards for such systems described in these Security Policies and Procedures.

Responsibility: Privacy & Security Officer;

Definitions: ePHI; ePHI System; Workforce Member; Workstation;

Regulatory Reference:

- ♦ 45 C.F.R. §164.312(a)(1), Access Control [Standard; Required]
- ♦ 45 C.F.R. §164.312(a)(2)(i), Unique User Identification [Implementation Specification; Required]
- ♦ 45 C.F.R. §164.312(a)(2)(ii), Emergency Access Procedure [Implementation Specification; Required]
- ♦ 45 C.F.R. §164.312(a)(a)(2)(iii), Automatic Logoff [Implementation Specification; Addressable]
- ♦ 45 C.F.R. §164.312(a)(a)(2)(iv), Encryption and Decryption [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 37
Title: Mobile Device Management (MDM)	**Revision: 1.0**	**Effective Date:**

PeriGen Mobile Device Management (MDM) Policy:

1. Introduction:

The HIPAA Privacy Rule establishes national standards for giving patients the right to access and request amendment of their protected health information (PHI) as well as requesting restrictions on the use or disclosure of such information. The HIPAA Security Rule establishes a national set of security standards for the confidentiality, integrity, and availability of electronic protected health information. The HIPAA Privacy and Security Rules apply to covered entities. Organizations that meet the definition of a covered entity and who transmit health information in electronic form in connection with certain transactions and operations must comply with the Rules' requirements to protect the privacy and security of health information, even when using mobile devices.

2. Background:

The HIPAA Privacy and Security Rules were drafted and first implemented in the early part of the 2000s when mobile devices, as we now know and use them, did not exist. They were used primarily for making and receiving telephone calls. Modifications and updates to the rules have been made, most notably with the 2013 Final Omnibus Rule, however specific rules and regulations in regard to the advancing technology of mobile devices has not occurred.

It would be shortsighted to think that HIPAA rules do not apply to mobile devices since there are no specific regulations governing their usage. HIPAA's expansive rules apply to all IT systems and cover mobile devices despite the term "mobile device" never appearing in either the Privacy or the Security Rules. However, the Privacy and Security Rules routinely reference "workstations," which is defined to mean "an electronic computing device, for example, a laptop or desktop computer, or *any other device that performs similar functions, and electronic media stored in its immediate environment*." *45 CFR § 164.304.*

In short, the Security Rule applies broadly to mobile devices. As such, numerous administrative, physical and technical safeguards must be utilized when mobile devices are being used to view, store, and transmit PHI. PeriGen's HIPAA Policies and Procedures along with the Privacy and Security Rules indirectly set forth the requirements for mobile device management. This document is meant to give specific guidelines to mobile device management (MDM) based on PeriGen's specific requirements based on PeriGen's size, complexity, and capabilities.

3. Overview of Requirements:

Acknowledging the HIPAA Privacy and Security Rules and regulations apply to "workstations" and also to "electronic media," these regulations fundamentally apply to current mobile devices given the manner in which modern mobile devices are used. "Electronic media" is defined to include electronic storage media on which data is or has the ability to be stored electronically, *45 CFR § 160.103*. There are several areas of the Rules which apply to mobile devices and electronic PHI (ePHI). The following points give a brief overview of a covered entity's role in adhering to the Privacy and Security Rules as it pertains to mobile devices:

- Implement policies and procedures to prevent, detect, contain, and correct security violations. *45 CFR § 164.308*
- Implement procedures to regularly review records of information system activity such as audit logs, access reports, and security incident tracking reports. *45 CFR § 164.308(a)(1)(ii)(D).*
- Implement hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use electronic PHI. *45 CFR § 164.312(b).*
- Implement policies and procedures to ensure that all members of its workforce have appropriate access to ePHI, and to prevent workforce members who do not have access from obtaining PHI. *45 CFR § 164.308(3)(1).*
- Implement periodic security updates. *45 CFR § 164.308(a)(5)(ii)(A).*
- Implement procedures for guarding against, detecting and reporting malicious software. *45 CFR § 164.308(a)(5)(ii)(B).*
- Implement procedures for monitoring log-in attempts and reporting discrepancies. *45 CFR § 164.308(a)(5)(ii)(C).*
- Establish and implement policies and procedures for responding to an emergency or other occurrence (i.e. fire, vandalism, system failure, and/or natural disaster) that damages systems that contain ePHI. *45 CFR § 164.308(a)(7)(i).*
- Perform a periodic technical and non-technical evaluation, based initially upon the standards implemented under this rule and subsequently, in response to environmental or operational changes affecting the security of ePHI. *45 CFR § 164.308(a)(8).*
- Implement technical policies and procedures for electronic information systems that maintain ePHI to allow access only to those persons or software programs that have been granted access rights as specified in *45 CFR § 164.308(a)(4).*
- Implement procedures to verify that a person or entity seeking access to ePHI is the one claimed. *45 CFR § 164.312(d).*
- Implement technical security measures to guard against unauthorized access to ePHI that is being transmitted over an electronic communications network. *45 CFR § 164.312(e)(1).*
- Implement a mechanism to encrypt ePHI whenever deemed appropriate. *45 CFR § 164.312(e)(2)(i)-(ii).*
- Ensure the confidentiality, integrity, and availability of all ePHI that the covered entity creates, receives, maintains, or transmits. *45 CFR § 164.306(a)(1).*
- Protect against any reasonable anticipated threats or hazards to the security or integrity of such information. *45 CFR § 164.306(a)(2).*
- Protect against any reasonably anticipated uses or disclosures of such information that are not permitted or required. *45 CFR § 164.306(a)(3).*
- Maintain a record of the movements of hardware and electronic media and any person responsible therefore. *45 CFR § 164.310(d)(2)(iii).*

- Review and modify the security measures implemented as needed to continue the provision of reasonable and appropriate protection of ePHI. *45 CFR § 164.306(e).*
- Implement a mechanism to encrypt and decrypt ePHI. *45 CFR § 164.312(2)(iv).*

It is important to note that this summary of requirements for mobile devices includes laptops, tablets, and mobile smartphones, regardless if the device is owned by PeriGen or if the device is personally owned by the individual (Bring Your Own Device or BYOD).

In regards to (Bring Your Own Device or BYOD): In general, the use of personal computers for daily work is prohibited at PeriGen and **only** a PeriGen issued device should be used.

The following exceptions can apply to this rule:

- Use of personal iPad or phones purchased through PeriGen or secured by PeriGen for use at specific facilities.
- Accessing email through the Office 365 portal on a personal device (since the licensure is HIPAA compliant)
- Accessing or viewing OneDrive documents through the app or Office 365 portal (since the licensure is HIPAA compliant)
- Devices must maintain and comply with policies applied from the PeriGen Office 365 instance
- Never use jailbroken devices (Apple) or "rooted" (Android based) devices.

4. Mobile Device Policy:

A. Purpose:

The purpose of this policy is to establish and outline the criteria governing the appropriate and authorized use of personal and/or corporate owned mobile devices where the owner or user has established access and uses these devices access to PeriGen's corporate networks, data, and systems. Mobile devices include but is not limited to mobile smartphones, laptops, tablets, and computers which have access to corporate systems enabling them to access data, send and receive work-related email messages and conduct other PeriGen business.

B. Policy Statement:

Mobile devices are important tools within PeriGen as they help to support daily operations and achieve business goals. However, mobile devices also pose a significant risk to corporate data security as these devices can serve as a pathway to unauthorized access to our organization's data and IT infrastructure. If the appropriate administrative, physical and technical safeguards as well as robust security applications and procedures are not applied, this unauthorized access can lead to significant data compromise and internal systemic infection. PeriGen has a responsibility to protect its corporate data and information systems in order to protect its PHI/ePHI, patient privacy, intellectual property and reputation in the local medical community.

C. Scope of Policy:

This policy applies to all mobile devices, both owned by PeriGen or owned by a workforce member, inclusive of mobile smartphones, laptops, tablets, and other computers, that have access to PeriGen corporate IT networks, data, cloud and computer systems. Applications used by workforce members on their own personal devices which store, record or access corporate data or ePHI, such as cloud storage applications and patient medical record keeping, are also subject to this policy.

D. User Responsibility:

1. **General—**Workforce member agrees to an organizational general code of conduct that acknowledges the need to protect confidential corporate and patient data that is stored on or accessed using a mobile device. This code responsibility includes but is not limited to:

   i) Only loading or accessing corporate data that is essential to their role in the organization onto mobile devices
   ii) Ensuring adequate physical security of the device
   iii) Maintaining the software configuration of the device by having both the operating system and applications installed
   iv) Preventing the storage of sensitive company data and PHI in unapproved applications on the device, including uninstalling and/or disabling unapproved file sharing applications.
   v) Making sure the device's security controls are not disrupted by hacks, jailbreaks, security software changes and/or security setting changes.
   vi) Immediately report a lost or stolen device to the corporate IT service provider, the Privacy & Security Officer and the Director of Compliance & Quality vii) If a user suspects that unauthorized access to corporate data has occurred through a mobile device, the workforce member must report the incident in accordance to company policy.
   viii) Devices must not be "jailbroken" or "rooted" or have any software/firmware installed which is designed to gain access to device functionality ix) Users must not load unauthorized or pirated software or illegal content onto their devices
   x) Applications must only be installed from official platform-owner approved sources. Installing applications from unknown or untrusted sources is prohibited.
   xi) Devices must be kept up to date with any manufacturer or network provided patches on a regular basis (at least once per month).
   xii) All devices used for work-related purposes must have software, applications, and encryption (if applicable) installed and enabled according to corporate standards and policy.
   xiii) Workforce members must not use corporate workstations to backup or synchronize device content such as media files, unless device content is required for legitimate business purposes. Likewise, corporate mobile devices may not be synchronized to other personal devices in a workforce member's home or residence.

xiv) Workforce members are prohibited from using any cloud-based applications or backup that allows corporate data to be transferred to unsecure parties.

xv) The above requirements will be checked as deemed necessary and if a device is found to be non-compliant, actions may include the loss of access to company email, **complete disabling of access** to all company applications or programs, a device lock or in severe cases, a device wipe (of a PeriGen issued device).

2. **Personally Owned Devices—**This includes mobile devices, such as personal smartphones, laptops, and tablets, which are not owned by PeriGen or centrally managed by corporate IT services. As such, a support need or technical issue related to the personally owned device is the responsibility of the device owner. The workforce member is responsible for:

i) Maintaining adequate service and proper billing with carrier

ii) Purchasing and using any required software as dictated by the organization which is not provided by the manufacturer or wireless carrier

iii) Device registration with the vendor and/or IT service support as directed

iv) Maintaining necessary warranty coverage

v) Battery maintenance and replacement as needed to maintain a charge to the device

vi) Backing up all data, settings, media and applications on a regular basis vii) Using a secure password that complies with the corporate password policy to enter/log in to device and to log in to various applications within the device which require a password (for example, Outlook email, Office 365, OneDrive, etc.)

viii) Installation of up to date software updates and patches

ix) Device registration with corporate IT services as required by the organization

x) Agreement by workforce member to strictly follow any mandate dictated by the organization as it relates to using a specific program, software, policy or security protocol on personally owned devices which are used for any work-related purpose. The workforce member is responsible for the backup of their own personal data. PeriGen will accept no responsibility for the loss of personal files due to a noncompliant device being wiped for security reasons.

xi) Family member, friends, and/or associates should not use a workforce member's personal mobile device which is ~~ever~~ used for company purposes.

xii) Personal and work email accounts should not be merged on devices. Only company data should be sent the corporate email system. If a user suspects that company data (especially data containing PHI) has been sent from a personal email account, either in subject, email body text or attachment(s), the workforce member must report the incident in accordance to company policy.

xiv) Workforce members whose personal mobile devices have camera, video or recording capability are prohibited from using these functions to photograph, video or record corporate data (especially data containing PHI), conversations or data unless authorized in advance by management.

3. **Corporate Owned Devices—**Corporate owned mobile smartphone, laptops, and tablet devices will be centrally managed by corporate IT services or the organization's designee. The workforce member is responsible for:

i) Using the device for work-related purposes and not for personal use or purposes
ii) Using a secure password that complies with the corporate password policy to enter/log in to device and to log in to various applications within the device which require a password.
iii) Devices must store all user-saved passwords in an encrypted password store or otherwise password protected means and must never be written down or posted at work station.
iv) Workforce member must comply with the installation of all software updates as dictated by corporate IT service support.
v) Only devices in which the applications used to store or transmit ePHI are managed by corporate IT service support will be allowed to connect directly to the internal server/corporate network
vi) Corporate owned devices will be subject to the security features as dictated by corporate IT service support such as encryption, password protection, key lock, screen saver lock, etc. The policies for all corporate owned devices will be regulated by the corporate IT service support provider using the corporations chosen mobile device management software.
vii) Reporting a lost or stolen device immediately
viii) Reporting the known or potential unauthorized use of a corporate owned device by someone not affiliated with the corporation.
viii) Workforce members may not store information from or related to former employment on a corporate owned device.

E. <u>Best Practices Guidelines</u> (to be followed by all PeriGen workforce members):

1. Use a Password or other User Authentication

i) Mobile devices will require a password, personal identification number (PIN), passcode (pattern trace) or fingerprint identification to gain access to the device.
Passwords, PIN, and passcodes will be a secret and not stored on the mobile device.
ii) Workforce members will create a "strong" password which will be easy for the member to remember but hard for others to guess. The password should be at least six (6) characters in length and should include a combination of upper and lower case letters, at least one number and at least one special character, such as a punctuation mark.
iii) Passwords will be created and changed regularly in accordance to PeriGen's password management policy (24).
iv) Enable the mobile device time-out, screen lock or automatic logoff feature on devices.
v) Set devices to limit the number of unsuccessful login attempts.
vi) Disable speech recognition/voice control features.
vii) Limit access to device utilities and settings to authorized or authenticated user(s).
viii) Use other methods to authenticate your device such as camera, pattern gesture recognition, and biometrics (fingerprint recognition). Combining a password or

PIN with one of these other authentication methods provides further security to your device.

2. Install and enable encryption

i) Encryption is the conversion of data into a form that cannot be read without the decryption key or password.
ii) Devices will utilize encryption technology inherent to our HIPAA compliant E1 or E3 licensure through Microsoft Office 365 and OneDrive for corporate emails and storage of corporate data.
iii) Data stored locally on the mobile device (data at rest) and data sent by the mobile device (data in motion) must be encrypted, particularly if the data contains PHI.
iv)
v) OneDrive will be used to store corporate data/documents in a secure, encrypted container. Access to OneDrive will be password protected and authorized by the Privacy & Security Officer.
vi) PeriGen's policy is to NOT send PHI via text message.
vii) If any correspondence containing PHI has to be sent to workforce members and there is an issue or failure of encryption technology, all correspondence, emails, and attachments must be properly de-identified prior to being sent via standard email or other unencrypted means.

3. Install and Activate Remote Wiping and/or Remote Disabling

i) Remote wiping is a security feature that enables remote erasing of the data on a mobile device if the device is lost or stolen.
ii) Remote disabling is a security feature that enables one to remotely lock or completely erase data stored on a mobile device if it is lost or stolen. If the device is recovered, it has the ability to be unlocked.
iii) Corporate owned mobile devices used in PeriGen's office for business purposes will be equipped with Microsoft Office 365 management utilities which enables these devices to be remotely wiped.

iv) **The administrator of Office 365 for PeriGen can remotely disable all access to all Office 365 related products, such as Outlook and OneDrive. The administrator can also remove workforce members from access lists to prevent them from seeing all documents and files stored in OneDrive. With mobile device management through Office 365, there is the ability to do remote wiping of registered devices if needed.**
v) Actions which may result in a full or partial wipe of a mobile device, or other interaction by IT service support include:
   (1) A device that is jailbroken or rooted
   (2) A device which contains an application known to contain a security vulnerability (if not removed within a specific time-frame after informing the user of issue)

(3) A device that is lost or stolen

vii) Any decision to perform a selective or full wipe of a mobile device will be at the sole discretion of the managing board after reviewing information that supports this action being necessary. No individual within PeriGen has the authority to perform this action.

4. **Disable and do not install or use file sharing applications**

i) File sharing is software or a system that allows individual users of the internet to connect to each other and trade files.
ii) File sharing can enable unauthorized users to access your mobile device without your knowledge which puts your device and the information it holds at risk.
iii) PeriGen file sharing will be through OneDrive via Office 365. All files containing ePHI that is stored in OneDrive will be in "read only" format with "sharing" capabilities removed.
iv) Workforce members will disable all other file sharing applications on work-related mobile devices where corporate data and PHI is accessed.
v) Workforce members will not install file sharing applications on work-related mobile devices.
vi) Workforce members will create and maintain a passcode and/or fingerprint ID to access information on OneDrive.

5. Install and enable a firewall

No PHI is used on corporate mobile devices. Should this change, the following measures will be considered to further secure mobile devices:

i) A firewall on a mobile device can protect against unauthorized connections.
ii) Firewalls intercept incoming and outgoing connection attempts and either blocks or permits the connection based on a set of rules.
iii) All corporate owned devices will have firewalls installed and enabled per the software recommendations of PeriGen's corporate IT service support
iv) All personally owned mobile devices will have firewalls enabled and active while using the mobile device to conduct PeriGen business.

6. Install and enable security features

i) Security software protects mobile devices against malicious software such as viruses, spam and malware.
ii) All corporate owned devices will have security software installed, enabled, managed and updated by PeriGen's corporate IT service support.
iii) Workforce members are responsible for security software on all personally owned devices. The device operating system software must be kept current with all updates, including security updates.

iv) Workforce member agrees to enable security software included on personally owned mobile device, and if not included, download security software to the mobile device.
v) Limit access to mobile device utilities and settings to authorized or authenticated user(s).
vi) Workforce member agrees to random checks of mobile device configuration to ensure compliance with all applicable corporate security policies if deemed necessary.
vii) Devices must not be connected to a PC or other unit which does not have up to date and enabled anti-virus/anti-malware protection and which does not comply with corporate security policy.
viii) All workforce members must comply with the requirements of MDM through use of Office 365 and its HIPAA compliant applications. If additional security requirements and/or the need for a MDM software on personal devices are deemed potentially necessary due to practice dynamic, this need will be evaluated at the PeriGen senior management level. PeriGen senior management has the ultimate authority to **approve or deny** any software and/or applications to be used on PeriGen issued, PeriGen owned or personal devices used within the Practice. PeriGen senior management has the ultimate authority to **require use of** any software and/or application to be used on PeriGen issued, PeriGen owned or personal devices used within the Practice.

7. Keep security software up to date

i) Updating security software ensures the latest tools to prevent unauthorized access to PHI is available on your mobile device.
ii) Set devices to automatically transfer software updates directly to mobile devices when these updates become available from the manufacturer or wireless carrier. iii) Aid the prompt transmission of security software updates by turning on and using features such as automated update options or vendor notification options.
iv) Install security software updates as soon as they become available. Avoid using the "remind me later" option on your mobile device.
v) Update key applications and the device operating system (OS) regularly to ensure the most up to date and secure versions are available for your mobile device.
vi) Configure your device to alert you of application and system updates and make sure any software updates require your authorization (passcode) to proceed.
vii) All PeriGen workforce members agree to keep security software on mobile devices updated at all times.

8. Research mobile applications (apps) before downloading

i) A mobile app is a software program for mobile devices. Examples include: games, note taking programs, and health related tools, such as EHR software.
ii) A mobile app has the ability to compromise data on a mobile device, especially if it is from an unknown source.

iii) Before downloading and installing apps on your mobile device, verify that the app will only perform functions which you approve.
iv) If apps must be downloaded, use only known, trusted websites and sources who have reputable reviews of the app.

9. Maintain physical control

i) The benefits of mobile devices, such as portability, small size and ability to be concealed, are also some of the features that pose a challenge in protecting and securing these devices which often contain PHI as these devices can be easily lost or stolen.
ii) A mobile device that is accessible to unauthorized users poses a risk to the confidentiality, integrity and availability of PHI on the mobile device. iii) Physically securing the mobile device can limit the risk of unauthorized users tampering with or stealing the device. iv) Workforce members agree to maintain physical control of their mobile device by adhering to the following:

(1) Physically secure your mobile device—locking mobile device in a secure location, such as a locked drawer or behind a locked office door, prevents unauthorized users from accessing data through or on the device.
(2) Lock mobile device screen when not using it—Require passcode access on the mobile device to unlock the screen. Also set mobile devices to automatically timeout/logoff to lock screen after a set time of inactivity.
(3) Keep your mobile device with you or physically secure your mobile device if you cannot keep it on your person.
(4) Do not let others use your mobile device—by sharing your mobile device with others, you can increase the risk of an unauthorized user accessing PHI through your device.

10. Use adequate security to send or receive health information over public Wi-Fi networks

i) The risk of using a public Wi-Fi network or hotspot is that information can be intercepted between the mobile device and the system connection.
ii) A secure Wi-Fi connection uses encryption that helps you keep data safe from interception by an unauthorized third party when data is being transmitted.
iii) The secure portal allows for secure transmission of ePHI in an encrypted form even while using a public Wi-Fi network.
iv) All PeriGen files stored in OneDrive is secured in transit and at rest as a feature of PeriGen's Office 365 enterprise licensing. Therefore, logging into OneDrive will put the user into a secure container even if a public Wi-Fi network is being used.
v) Try to limit internet browsing or use to secure browser connections. A secure browser connection will display "https" in the website address.
vi) Consider turning off Wi-Fi, location services, and Bluetooth functionality when not in use.

vii) A Virtual Private Network (VPN) is one way to create a secure connection over a public unsecured Wi-Fi network. It creates an encrypted connection between your mobile device and the server, so the information sent and received is protected by the encrypted conduit created by the VPN, even on a public, unsecured network.

viii) Workforce members should strongly consider using a VPN when using personal mobile devices for work-related purposes, especially when an unsecured public Wi-Fi network must be used for internet access.

11. Delete all stored health information before discarding or reusing the mobile device

i) Corporate owned devices are equipped with Microsoft Office 365 management utilities which gives corporate IT service support the ability to delete or wipe the device and any PHI stored on the device before it is discarded or reused. This ensures PHI and other corporate data is protected and secured from unauthorized use.

ii) The Office for Civil Rights (OCR) affiliated with the U.S Department of Health & Human Services (HHS) has guidelines established for the proper removal of PHI and other sensitive data stored on mobile devices prior disposal or reuse of the device. The methods include:

(1) Clearing—using software or hardware products to overwrite media with no sensitive data

(2) Purging—degaussing or exposing the media to a strong magnetic field in order to disrupt the recorded magnetic domains

(3) Destroying—disintegrating, pulverizing, melting, incinerating, or shredding the media

iii) PeriGen's "Device and Media Controls" policy (#35) gives specific details regarding our commitment to delete all stored PHI on devices prior to discarding or reusing them.

F. <u>MDM Policy Enforcement</u>

1. Any workforce member who willingly violates, or refuses to comply with, the mandates set forth in the MDM Policy may be subject to disciplinary action guided by PeriGen's disciplinary action plan and/or from direct guidance from the Management Committee or upper level management.

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 38
Title: Integrity	**Revision: 1.0**	**Effective Date:**

HIPAA Security Rule Language: "Implement policies and procedures to protect electronic PHI from improper alteration or destruction." 45 CFR § 164.312(c)(1).
"Implement electronic mechanisms to corroborate that electronic PHI has not been altered or destroyed in an unauthorized manner. 45 CFR § 164.312(c)(2).

Purpose Statement: To safeguard ePHI, it is important to ensure that ePHI has not been altered or destroyed in an unauthorized manner. Therefore, when applicable, PeriGen will take reasonable and appropriate steps to protect the integrity of ePHI that PeriGen creates, receives, maintains, or transmits.

Policy/Procedure:

1. Where possible, Workforce Members and Users will have only read-only access to ePHI.
2. However, if a Workforce Member's or User's job function requires the alteration of ePHI, he or she will be granted read/write access to ePHI.
3. Each addition that a Workforce Member or User makes to an existing record containing ePHI will be treated as a new entry and will be logged in accordance with the Policy and Procedure #16 "Information System Activity Review; Audit Controls."
4. If a Workforce Member or User modifies an existing record containing ePHI, the ePHI System on which the record is contained will log the modification in accordance with the Policy and Procedure #16 "Information System Activity Review; Audit Controls."
5. Workforce Members and Users will not destroy ePHI without first providing notice to and receiving authorization from the Privacy & Security Officer in accordance with the Policy and Procedure #33 "Device and Media Controls Policy."
6. It is not reasonable or appropriate for PeriGen to authenticate **ePHI** for the following reasons:
    a. The amount of ePHI that PeriGen creates and retains is limited.
    b. The majority of PeriGen's access to ePHI is in read-only mode.
    c. PeriGen has sufficient policies in place that minimizes the need to authenticate ePHI.

Responsibility: Privacy & Security Officer
Definitions: ePHI; ePHI System; Workforce Member;
Regulatory Reference:

- ♦ 45 C.F.R. §164.310(c)(1), Integrity [Standard; Required]
- ♦ 45 C.F.R. §164.310(c)(2), Mechanisms to Authenticate Electronic PHI [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 39
Title: Person or Entity Authentication	**Revision: 1.0**	**Effective Date:**

HIPAA Security Rule Language: "Implement procedures to verify that a person or entity seeking access to electronic PHI is the one claimed." 45 CFR § 164.312(d).

Purpose Statement: To protect the confidentiality, integrity, and availability of ePHI, PeriGen will maintain a documented process for verifying the identity of any person or entity prior to granting access to ePHI.

Policy/Procedure:

1. PeriGen requires the use of individual user IDs and passwords before access to ePHI is granted.
   a. IDs are assigned in accordance with the Workstation Use and Security Policy.
   b. Workforce Members choose complex and confidential passwords in accordance with the Password Management Policy.
2. When feasible, PeriGen will mask, suppress, or otherwise obscure the passwords of persons and entities seeking access to ePHI so that unauthorized persons are not able to observe such passwords.
3. PeriGen will limit the authentication attempts of persons seeking access to ePHI to three consecutive attempts. Authentication attempts that exceed this limit may result in:
   a. Logging of the event for review;
   b. Disabling of the Workforce Member's password; or
   c. Notifying the Privacy & Security Officer or other appropriate PeriGen official.

Responsibility: Privacy & Security Officer

Definitions: ePHI; ePHI System; Workforce Member;

Regulatory Reference:

- ♦ 45 C.F.R. §164.312(d), Person or Entity Authentication [Standard; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 40
Title: Transmission Security	**Revision: 1.0**	**Effective Date:**

HIPAA Security Rule Language: Implement technical security measures to guard against unauthorized access to electronic PHI that is being transmitted over an electronic communications network. 45 CFR § 164.312(e)(1).

"Implement security measures to ensure that electronically transmitted electronic PHI is not improperly modified without detection until disposed of.

Implement a mechanism to encrypt electronic PHI whenever deemed appropriate." 45 CFR § 164.312(e)(2)(i)-(ii).

Purpose Statement: To ensure the confidentiality, integrity, and availability of ePHI, PeriGen will implement technical security measures to guard against unauthorized access to ePHI while it is transmitted over electronic communications networks.

Policy/Procedure:

1. PeriGen has implemented security protocols to protect data while such data is being electronically transmitted.

2. Unauthorized access to ePHI transmitted over electronic communications networks is prevented through the use of the administrative, technical and physical safeguards for all ePHI systems described in these Privacy and Security Policies and Procedures.

Responsibility: Privacy & Security Officer;

Definitions: ePHI

Regulatory Reference:

- ♦ 45 C.F.R. §164.312(e)(1), Transmission Security [Standard; Required]
- ♦ 45 C.F.R. §164.312(e)(2)(i), Integrity Controls [Implementation Specification; Addressable]
- ♦ 45 C.F.R. §164.312(e)(2)(ii), Encryption During Transmission [Implementation Specification; Addressable]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 41
Title: Availability	**Revision: 1.0**	**Effective Date:**

HIPAA Security Rule Language: "Make documentation available to those persons responsible for implementing the procedures to which the documentation pertains." 45 CFR § 164.316(b)(2)(ii).

Purpose Statement: PeriGen will make all documentation available to those persons responsible for implementing the procedures to which the documentation pertains.

Policy/Procedure:

1. PeriGen will make the following documentation available:
   a. Policies and procedures regarding the security of ePHI and ePHI Systems.
   b. All documentation that records any updates, revisions, modifications, or deletions made to existing Security Policies and Procedures.
   c. All policies and procedures no longer in effect for a certain Security Regulation requirement or implementation specification.
   d. Any other documentation that the Privacy & Security Officer deems appropriate to retain and to make available to its Workforce Members regarding PeriGen's Security Policies and Procedures.
2. The Privacy & Security Officer will be responsible for ensuring that such documentation as required by the HIPAA Security Regulations is made available to its Workforce Members.

Responsibility: Privacy & Security Officer

Definitions: ePHI; ePHI Systems; Workforce Member;

Regulatory Reference:

- ♦ 45 C.F.R. §164.316(b)(2)(ii), Availability [Implementation Specification; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

	HIPAA Security	Procedure No.: 42
Title: Updates	**Revision: 1.0**	**Effective Date:**

HIPAA Security Rule Language: Review documentation periodically, and update as needed, in response to environmental or operational changes affecting the security of the electronic protected health information. 45 CFR § 164.316(b)(2)(iii).

Purpose Statement: PeriGen will periodically review its Security Policies and Procedures, and will update these Policies and Procedures as needed, in response to environmental or operational changes affecting the security of ePHI.

Policy/Procedure:

1. PeriGen will review these Security Policies and Procedures at least once per year as part of its annual risk analysis.
2. Such environmental or operational changes, which would require a potential update of PeriGen's Security Policies and Procedures include, but are not limited to: a. Known Security Incidents;
   b. Significant new threats or risks to the security of ePHI;
   c. Introduction of new ePHI Systems;
   d. Changes to PeriGen's organizational or technical infrastructure;
   e. Changes to information security requirements or responsibilities; or
   f. Availability of new security technologies or recommendations.
3. The Privacy & Security Officer will oversee the method of updating the Security Policies and Procedures and will ensure that such updating occurs.

Responsibility: Privacy & Security Officer

Definitions: ePHI; Security Incident

Regulatory Reference:

- ♦ 45 C.F.R. §164.316(b)(2)(iii), Updates [Implementation Specification; Required]

Revision History:

Revision Level	Revision Description	Effective Date
1.0	Initial Policy	October 1, 2018

ATTACHMENT A

Retention Policy

PeriGen generates and maintains many different types of records, including PHI and business records. These records help practices maintain critical information and delivery quality services and care.

Because of their key role, records need to be appropriately maintained and managed throughout their lifecycle from creation to destruction.

PeriGen will comply with all laws, rules and regulations regarding records retention and records retention periods.

This policy will include:

- Length of time records will be maintained;
- List of records that will be maintained onsite or server;
- Director of Quality and Regulatory– responsible for maintaining record retention policies and initiating the destruction of records;
- Required methods for destructing records while preserving confidentiality (i.e., shredding, disposal, incineration, physical destruction of hard drives via vendors, high level overwriting of e-information, etc.);
- Documenting the destruction of records

PHI

The Centers for Medicare and Medicaid Services (CMS) requires records of providers submitting cost reports to be retained in their original or legally reproduced form for a period of at least **5** years after the closure of the cost report *(CFR 482.24[b][1]).*

According to North Carolina, Medical Doctors are to retain patient documents **7** years from the date of the last treatment for adult patients; and **7** years after the date of the last treatment or until the patient reaches 21, whichever date is later, for minor patients

HIPAA requires that medical records be retained for two years after a patient's death.

Financial Records

The chart below will identify state record-keeping laws for financial and Human Resources documents:

Document Type	Retention Period
Accounts payable/receivables	7 years
Audit Reports	Permanently
Bank Statements	3 years
Checks (cancelled)	7 years
Drug Test Records	1 year from test date
Employment Applications	3 years
Expense Analyses/Distribution	7 years
Financial Statements	Permanently
Insurance Policies (expired)	3 years
Invoices (to customers, from vendors)	7 years
Payroll Records	7 years
Petty Cash Vouchers	3 years
Tax Records	4 years from date tax is due/paid
Time Books/Cards	7 years
Withholding Tax Statements	7 years

Source: Internal Revenue Service

E-mails:
Under the HIPAA rules and regulations, electronic records of disclosures of PHI can be stored for up to 3 years. A disclosure of PHI can be the transmission of data from you to someone outside of the PeriGen organization.

All other e-mails may be deleted until the purpose of record has been fulfilled.

Other Business Documents:
All minute books and/or agendas from meetings, directors, C-Suite, Management Committee, and other board meetings must be kept permanently on file or electronically. Staff meeting minutes and notes will be retained for up to 1 year. Any strategic planning documents must be kept until the purpose of the record has been fulfilled plus 6 additional years, according to the North Carolina Library and Archives Commission Retention Schedule.

Any training materials used to train Workforce Members must be on file until an updated version has replaced plus one additional year.

DESTRUCTION OF RECORDS:
Paper records must be destroyed by shredding. PeriGen have a contract with a paper-shredding vendor, Shred-it; the vendor comes once a month to pick up any documents needed shredding and PeriGen records the invoices in the vendor files with the Human Resources Department.

PeriGen has a BAA on file with Shred-it due to the records being destroyed contains PHI.

Electronic records must be deleted and destroyed with a method that provides for no possibility of reconstruction of information. This may involve overwriting of electronic media, magnetic degaussing, pulverizing, cutting, or physically destructing hard drives. PeriGen have a contract with the IT vendor, VelocIT or assigned on site Workforce Member that handles destruction of all electronic records; any equipment that DSI is not able to destruct, the Privacy & Security Officer will contact a to-be-determined vendor to schedule destruction (i.e., floppy discs, CDs, hard drives, etc.).

DOCUMENTATION:
As part of the record disposal process, PeriGen has established a method to document the destruction of records. AHIMA recommends that organizations maintain a destruction log that includes:

- Method of destruction
- Date of destruction
- Description of the records that were destroyed (i.e., name, DOB, SSN, etc.)
- Signature of the Privacy & Security Officer to document scheduling of destruction

Resources

- CMS: MLN Matters® Number: SE1022 https://www.cms.gov/Outreach-and-Education/Medicare-Learning-NetworkMLN/MLNMattersArticles/downloads/SE1022.pdf

APPROVAL:
Retention Policy

REVISION HISTORY

Revision By	Description	Revision Date
Brian Bishop	Initial Creation	10/1/2018
Brian Bishop	Updated Covered Entity/Business Associate Language Added Revision History Table	5/22/2019